

Question 1 of 82

An organization has been vulnerable to a specific CVE for two years. Last week a metasploit module was released to exploit the vulnerability in an automated fashion. What happened to the vulnerability?

- ☐ It increased
- ☐ It changed categories
- ☐ It decreased
- ☐ It remained the same

全82問中1問目

ある組織は、2年間特定のCVEに対して脆弱な状態に置かれていました。先週、その脆弱性を自動的に悪用するMetasploitモジュールがリリースされました。この脆弱性はどうなったのでしょうか？

- ☐ 増加した
- ☐ カテゴリーが変わりました
- ☐ 減少した
- ☒ それは変わらなかった

Question 2 of 82

What guideline should be followed when setting up a secure ICS network architecture?

- ☐ Enterprise Active Directory should not extend to level 4 (Business Network)
- ☐ Require traffic between the business and control networks to stop at a server in the DMZ
- ☐ Place patch management servers for the control networks in the ICS DMZ
- ☐ Internet access should not go deeper than level 3 (Site-Wide Supervisory)

全82問中2問目

安全なICSネットワークアーキテクチャを構築する際に、どのようなガイドラインに従うべきでしょうか？

- ☐ エンタープライズActive Directoryはレベル4（ビジネスネットワーク）まで拡張すべきではありません。
- ☒ ビジネスネットワークと制御ネットワーク間のトラフィックをDMZ内のサーバーで停止させるようにする。
- ☐ 制御ネットワーク用のパッチ管理サーバーをICS DMZに配置する
- ☐ インターネットアクセスはレベル3（サイト全体の監視）より深いレベルまで到達させてはならない。

全82問中2問目

安全なICSネットワークアーキテクチャを構築する際に、どのようなガイドラインに従うべきでしょうか？

- ☐ エンタープライズActive Directoryはレベル4（ビジネスネットワーク）まで拡張すべきではありません。
- ☒ **ビジネスネットワークと制御ネットワーク間のトラフィックをDMZ内のサーバーで停止させるようにする。**
- ☐ 制御ネットワーク用のパッチ管理サーバーをICS DMZに配置する
- ☐ インターネットアクセスはレベル3（サイト全体の監視）より深いレベルまで到達させてはならない。

☒ **その通りです**

安全なICSネットワークを構築するための推奨サイバーセキュリティガイドラインには、次のものが含まれます。1) インターネットアクセスと電子メールがレベル4より深く進まないこと、2) エンタープライズActive Directoryをレベル4より下に拡張しないこと、3) ビジネスネットワークと制御ネットワーク間のすべてのトラフィックがICS DMZ内のサーバーで停止するようにすること、4) 制御ネットワークのパッチ管理サーバーをパデューレベル3に配置すること。

Question 3 of 82

What recommended practice should vendors follow to protect passwords?

- ☐ Prefer SMS based multi factor authentication over token based
- ☐ Do not permit customer-based complexity requirements
- ☐ Support distributed credential storage and management
- ☐ Do not restrict which special characters can be used

全82問中3問目

ベンダーはパスワードを保護するために、どのような推奨事項に従うべきでしょうか？

- ☐ トークンベースの多要素認証よりもSMSベースの多要素認証を優先する
- ☐ 顧客ベースの複雑性要件を許可しない
- ☐ 分散型認証情報の保存と管理をサポートする
- ☒ **使用できる特殊文字を制限しないでください**

☒ **その通りです**

ベンダーは、パスワードを保護するために以下のガイドラインに従うべきです。まず、使用できる特殊文字を制限してはなりません。次に、トークンベースの多要素認証（MFA）よりもSMS認証を優先してはなりません。さらに、顧客が独自の複雑性要件を設定できるようにする必要があります。そして、ベンダーは集中認証をサポートし、1) 認証情報が複数の場所ではなく1か所で管理・保存され、2) ユーザーは1か所でパスワードを変更するだけで済み、3) ユーザーは複数の認証情報ではなく1セットの認証情報を記憶するだけで済むようにする必要があります。これらの対策により、ユーザーはアカウントを共有する必要がなくなります。

Question 4 of 82

Which level of the Purdue Enterprise Reference Architecture (PERA) groups systems that support site-wide operations?

- ☐ 2
- ☐ 3
- ☐ 5
- ☐ 4

全82問中4問目

Purdue Enterprise Reference Architecture (PERA) のどのレベルで、サイト全体の運用をサポートするシステムがグループ化されていますか？

- ☐ 2
- ☒ 3
- ☐ 5
- ☐ 4

✔ その通りです

パデューモデルでは、システムを0から4までの5つの異なるレベルに分割することを提案しています。レベル0は最も低いレベルで、物理的なプロセスを表し、そのグループのプロセスを構成する直接的なセンサーとアクチュエータが含まれます。レベル1には、そのグループのプロセスのコントローラが含まれます。レベル2には、各グループのプロセスに固有のローカル監視システムが含まれます。プロセスグループの上には、工場全体または地域全体のレベル3があり、そのサイトまたはその地域のすべてのプロセスグループを制御する監視システムが含まれます。レベル3には、運用をサポートするシステムで構成されますが、プロセスのリアルタイム実行には直接関与しない運用サポートも含まれます。レベル4は、ICSに関連する組織のビジネス面を表します。パデュー

されますが、プロセスのリアルタイム実行には直接関与しない運用サポートも含まれます。レベル4は、ICSに関連する組織のビジネス面を表します。パデューモデルの現代的な進化では、多くの場合、すべての企業ビジネスユニットに対するエンタープライズサポートを表すレベル5が含まれます。

Question 5 of 82

Which of the following is the most direct threat to an air-gapped system?

- ☐ Phishing attack
- ☐ Fuzzing attack
- ☐ ARP spoofing attack
- ☐ USB thumb drive containing malware
- ☐ Internet worm known to attack ICS systems

全82問中5問目

エアギャップシステムにとって最も直接的な脅威となるのは次のうちどれですか？

- ☐ フィッシング攻撃
- ☐ ファジング攻撃
- ☐ ARPスプーフィング攻撃
- ☒ マルウェアを含むUSBメモリ
- ☐ ICSシステムを攻撃することが知られているインターネットワーム

✔ その通りです

高度な攻撃は、もともとUSBメモリを介して導入されたと言われており、悪意のある活動を行うためにシステムに物理的にアクセスすることの有効性を示しています。また、注目を集めた事件では、論理的に分離されたネットワークやエアギャップされたネットワークでさえ、このような攻撃に対して無敵ではないことが証明されています。遠隔地の施設の通信や機器を侵害するという概念も、決して新しいものではありません。セキュリティ専門家は、企業顧客向けに承認されたネットワーク侵入テストを実施する際に、しばしばこのような戦術を用います。

その他の攻撃はすべて、攻撃者がネットワーク上に存在することを前提としており、これはエアギャップによって防止されるべきである。

Question 6 of 82

What is described below?

An unmanned surface vehicle (USV) is supposed to travel at 30 knots.
If the velocity is 15 kn or less, the throttle is set to 100%.
If the velocity is between 15 kn and 20 kn the throttle is set to 75%.
If the velocity is between 20 kn and 25 kn the throttle is set to 50%.
If the velocity is between 25 kn and 30 kn the throttle is set to 25%.

- ☒ Fuzzy logic
- ☐ Sequential function block
- ☐ PID loop
- ☐ Ladder logic
- ☐ Instruction list

以下に説明されている内容は何ですか？

An unmanned surface vehicle (USV) is supposed to travel at 30 knots.
If the velocity is 15 kn or less, the throttle is set to 100%.
If the velocity is between 15 kn and 20 kn the throttle is set to 75%.
If the velocity is between 20 kn and 25 kn the throttle is set to 50%.
If the velocity is between 25 kn and 30 kn the throttle is set to 25%.

☒ **ファジーロジック**

- ☐ シーケンシャルファンクションブロック
- ☐ PIDループ
- ☐ ラダーロジック
- ☐ 手順一覧

☒ **その通りです**

ファジー論理は「真偽の度合い」に関係します。USVが30ノットを超えて移動

☒ **その通りです**

ファジー論理は「真偽の度合い」に関係します。USVが30ノットを超えて移動している場合、それは速すぎる速度で移動していますが、論理式で単にyesまたはno;1または0を使用した場合、「どれくらい」速すぎるかはわかりません。31ノットでの移動も速すぎますし、70ノットでの移動も速すぎますが、これらの状態それぞれに対して異なる対応が必要になる場合があります。この論理式は、人が読みやすく、システムが何をすべきかを簡単に識別できます。これらの論理式は、数学的評価のためにファジー論理に変換されます。

ラダーロジックと命令リストは、プログラミング言語の一種である。

Question 7 of 82

What is an advantage of using virtualization in an ICS environment?

- ☐ Simplifies troubleshooting and monitoring
- ☐ Makes system patching and backups easier
- ☐ May be safely managed from any zone in the organization
- ☐ Works well across different trust zones on a single host

全82問中7問目

ICS環境において仮想化を利用する利点は何ですか？

- ☐ トラブルシューティングと監視を簡素化します
- ☒ システムのパッチ適用とバックアップが容易になります
- ☐ 組織内のどのゾーンからでも安全に管理できます
- ☐ 単一ホスト上の異なる信頼ゾーン間でも正常に動作します

✔ その通りです

ICS環境における仮想化の利点としては、リソースの統合、冗長性、テストおよびトレーニング環境の構築、パッチ適用とバックアップの管理の容易化などが挙げられます。仮想化は、同一ホスト上の異なる信頼ゾーンにまたがって構築すべきではありません。信頼ゾーンからのみ管理されるべきです。場合によっては、仮想化によってトラブルシューティングやシステム監視の複雑さが増すこともあります。

Question 8 of 82

What is an example of deterrence as a physical security defense?

- ☐ Physical walk-down
- ☐ Hidden cameras
- ☐ Bright lighting
- ☐ Audible alarms

全82問中8問目

物理的な安全保障対策としての抑止力の例を挙げてください。

- ☐ 物理的な徒歩移動
- ☐ 隠しカメラ
- ☒ 明るい照明
- ☐ 可聴アラーム

✔ その通りです

物理的なセキュリティ対策には、抑止、遅延、検知、対応が含まれます。抑止とは、攻撃者が攻撃を試みる可能性を低減するあらゆるセキュリティ機能を指します。例としては、有刺鉄線付きの高いフェンス、目に見えるカメラ、明るい照明、目立つ警備員などが挙げられます。侵入を施設職員に知らせる可聴アラームは、検知の一例です。完全に効果的な抑止策であれば、可聴アラームの使用は不要になります。物理的な巡回点検とは、経験豊富な現場職員が、何か紛失または異常がないかを確認するために行う検査です。

Question 9 of 82

Which of the following describes the process of modulation?

- ☐ Processing of carrier signals received by RF antennas
- ☐ Modification of digital data to become RF data
- ☐ Changing of carrier signal information for transmission
- ☐ Broadcasting of RF signals through the airwaves

全82問中9問目

次のうち、変調のプロセスを説明しているのはどれですか？

- ☒ RFアンテナで受信した搬送波信号の処理
- ☐ デジタルデータをRFデータに変換する
- ☒ 送信のための搬送波信号情報の変更
- ☐ 無線周波数信号を電波を通して送信すること

✖ あなたは間違っています

変調とは、搬送波と呼ばれる周期的な波形の1つまたは複数の特性を、通常は送信する情報を含む変調信号と呼ばれる別の信号で変化させるプロセスです。変調には主に2つの種類があります。1つ目は振幅変調（AM）で、信号の電力を変化させてデータを符号化します。2つ目は周波数変調で、搬送波の周波数をわずかに変化させてデータを表します。

Question 10 of 82

Which of the following would be used to hide a private network from an outside network?

- ☐ ACL
- ☐ DNS
- ☐ NAT
- ☐ DHCP

全82問中10問目

プライベートネットワークを外部ネットワークから隠蔽するために使用されるのは、次のうちどれですか？

- ☐ ACL
- ☐ DNS
- ☒ NAT
- ☐ DHCP

✔ その通りです

プライベートネットワークのアドレス空間を隠蔽するために用いられる技術は、ネットワークアドレス変換（NAT）と呼ばれる。

アクセス制御リストはアドレスを隠蔽しません。

DNSは、名前をIPアドレスに解決するサーバーです。

DHCPはネットワーク内のIPアドレスを管理します。

Question 11 of 82

According to the DHS suggested patch decision tree, what should a security team do after it is determined that a vulnerability affects their ICS?

- ☐ Determine if the operational needs are greater than the risk
- ☐ Analyze the vulnerability footprint
- ☒ Analyze the impact to the business needs and operations
- ☒ Determine if there is a work-around available

✘ You are incorrect

The team needs to determine if the vulnerability affects their ICS, if it doesn't they can continue normal operations, but if it does they need to determine if a workaround is available. If there is a workaround available they can use the workaround until a scheduled update window is available. If there is no workaround the team must determine if the operational needs is greater than the risk. This decision requires them to analyze the impact to the business needs & operations, and also the vulnerability footprint (two decisions after determining if the vulnerability affects the ICS).

全82問中11問目

国土安全保障省が提案するパッチ適用決定ツリーによると、セキュリティチームは脆弱性が産業制御システム（ICS）に影響を与えることが判明した場合、どのような対応を取るべきでしょうか？

- ☐ 運用上のニーズがリスクを上回るかどうかを判断する
- ☐ 脆弱性の痕跡を分析する
- ☒ **ビジネスニーズと業務への影響を分析する**
- ☒ **回避策があるかどうかを確認する**

☒ **あなたは間違っています**

チームは、脆弱性がICSに影響を与えるかどうかを判断する必要があります。影響がない場合は、通常どおり運用を継続できますが、影響がある場合は、回避策が利用可能かどうかを判断する必要があります。回避策が利用可能な場合は、予定されているアップデート期間が利用可能になるまで、その回避策を使用できます。回避策がない場合は、運用上のニーズがリスクよりも大きいかどうかをチームが判断する必要があります。この判断には、ビジネスニーズと運用への影響、および脆弱性のフットプリントを分析する必要があります（脆弱性がICSに影響を与えるかどうかを判断した後の2つの判断）。

Question 12 of 82

Which of the following IEEE standards specifies a framework for network authentication?

- ☐ 802.1x
- ☐ 802.11ac
- ☐ 802.11ad
- ☐ 802.3

全82問中12問目

次のIEEE規格のうち、ネットワーク認証のフレームワークを規定しているのはどれですか？

- ☒ **802.1x**
- ☐ 802.11ac
- ☐ 802.11ad
- ☐ 802.3

☒ **その通りです**

認証はIEEE 802.1xワーキンググループの任務であり、彼らはネットワーク認証のためのフレームワークを設計した。この認証フレームワークは、拡張認証プロトコル（EAP）と呼ばれる複数の異なる認証プロトコルに対応している。

Question 13 of 82

A reactor operator at a nuclear power plant can control Pump_A on Unit 1 and Pump_B on Unit 2 from a single, centralized HMI. What level of the Purdue model are the pumps in?

- ☐ Level 2
- ☐ Level 1
- ☐ Level 4
- ☐ Level 0
- ☐ Level 3

全82問中13問目

原子力発電所の原子炉運転員は、単一の中央集中型HMIから、1号機のポンプAと2号機のポンプBを制御できます。これらのポンプは、パーデューモデルのどのレベルに該当しますか？

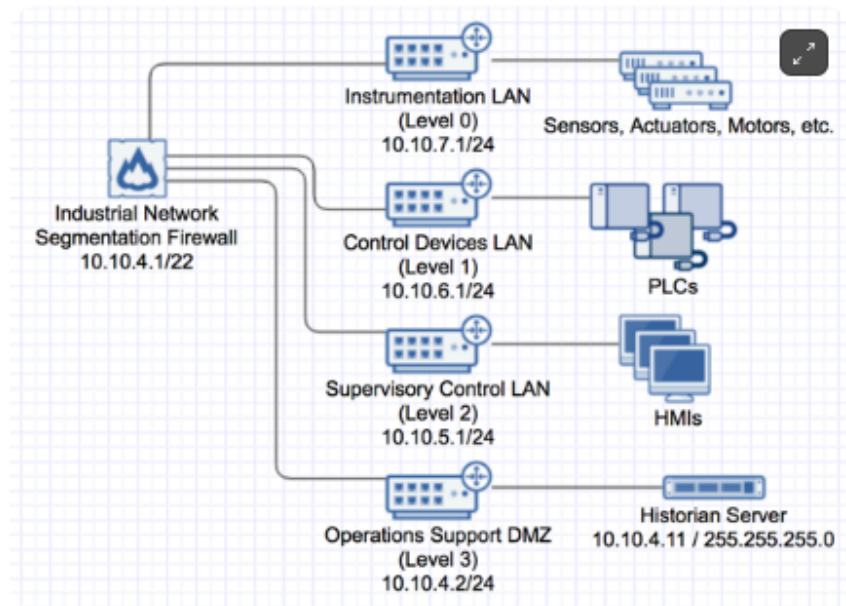
- ☐ レベル2
- ☐ レベル1
- ☐ レベル4
- ☒ レベル0
- ☐ レベル3

✔ その通りです

ポンプやバルブなどのコンポーネントは直接的なプロセスの一部であるため、レベル0に分類されます。HMIは工場全体に適用されるため、レベル2ではなくレベル3とみなされますが、これは下位レベルのコントローラーやポンプなどの機器には影響しません。

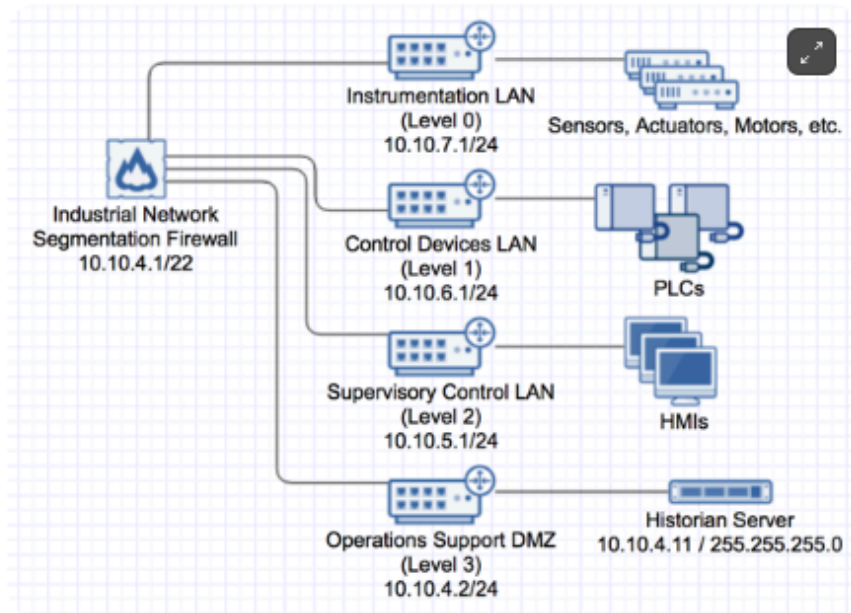
Question 14 of 82

Using the network diagram for context, which of the following source IP addresses would be blocked from connecting to the Instrumentation LAN by an anti-spoofing rule on the firewall?



- ☐ 10.10.4.3
- ☐ 10.10.6.24
- ☒ 10.10.7.187
- ☐ 10.10.5.77

ネットワーク図を参考に、ファイアウォールのなりすまし防止ルールによって計測LANへの接続がブロックされる送信元IPアドレスは次のうちどれですか？



- ☐ 10.10.4.3
- ☐ 10.10.6.24
- ☒ 10.10.7.187
- ☐ 10.10.5.77

✔ その通りです

保護されたネットワークアドレス空間内の送信元アドレスを含む受信パケットはすべて破棄する必要があります。これらのパケットが攻撃者によるアドレスのなりすましによるものか、ルーティングの問題によるものかにかかわらず、受信を許可してはなりません。10.10.4.0/24、10.10.5.0/24、および10.10.6.0/24ネットワークをブロックする理由は他にも考えられますが、なりすましは理由になりません。

Question 15 of 82

An exploitable vulnerability is discovered in a vendor's controller software. Which artifact would a security analyst look up, using a unique identifier assigned to the vulnerability, in order to read more detailed information about the identified issue?

- ☐ CWE
- ☐ CVSS
- ☐ TTP
- ☐ CVE

全82問中15問目

ベンダーのコントローラーソフトウェアに悪用可能な脆弱性が発見されました。セキュリティアナリストは、脆弱性に割り当てられた固有の識別子を使用して、特定された問題に関するより詳細な情報を読み取るために、どのアーティファクトを検索するでしょうか？

- ☐ CWE
- ☐ CVSS
- ☐ TTP
- ☒ CVE

✔ その通りです

特定のシステムにおける特定の脆弱性は、CVE固有のIDによって識別されます。

CVSSとは共通脆弱性評価システムの略で、脆弱性の深刻度を数値で表すための枠組みです。

CWEとは共通脆弱性列挙の略で、特定の脆弱性ではなく、高レベルの脆弱性に焦点を当てたものです。

TTPとは、戦術、技術、手順のことです。

Question 16 of 82

What is the function of a safety system (for example an SIS integrated into a plant's DCS)?

- ☐ Open interlocks on command
- ☐ Provide the control for hazardous materials in a process
- ☐ Provide predictable and timely fail-safe shutdown of the process
- ☐ Sets standards for plant personnel to safeguard themselves from injury
- ☐ Identify plant personnel locations during an emergency

全82問中16問目

安全システム（例えば、プラントのDCSに統合されたSIS）の機能は何ですか？

- ☐ 指示に応じてインターロックを開放する
- ☐ プロセスにおける危険物質の管理を提供する
- ☒ プロセスの予測可能かつタイムリーなフェイルセーフシャットダウンを提供する
- ☐ 工場従業員が怪我をしないようにするための基準を定める。
- ☐ 緊急時に工場職員の所在を特定する

✔ その通りです

安全システムの機能は、事前に定義された安全状態／事象が発生した場合に、人員、環境、設備、および制御システムを保護するために、ICSアプリケーションとプロセスを予測可能かつタイムリーにフェイルセーフシャットダウンすることです。安全システムは専用の目的を果たし、この種の産業制御システムを必要とするプロセスにとって不可欠な機能です。安全システムは人員の位置を特定する役割を担うものではなく、人員の安全に関する管理基準を設定するためにも使用されません。安全システムはプロセスの主要な制御を行うものではなく、常に監視を行い、危険な状態が発生した場合に備えて待機しています。最後に、インターロックを開くのは、いずれのシステムにも属さない機能です。

Question 17 of 82

Which of the following is commonly used to connect offshore oil platforms to primary control centers?

- ☐ WirelessHART
- ☐ Zigbee
- ☒ VSAT
- ☐ 802.11ac

全82問中17問目

洋上石油プラットフォームを主要制御センターに接続するために一般的に使用されるのは、次のうちどれですか？

- ☐ WirelessHART
- ☐ ジグビー
- ☒ VSAT
- ☐ 802.11ac

✔ その通りです

海上石油プラットフォームなど、あまりにも遠隔地にある場所では、機器を会社の中央制御センターに接続する唯一の方法として、衛星（VSATなど）アップリンクが選択肢となる場合がある。

WirelessHART、ZigBee、Wi-Fi（IEEE 802.11a、b、g、n、acなど）プロトコルでは、このような遠隔地に必要な距離をカバーすることはできません。

Question 18 of 82

Which of the following is a vulnerability specific to an authentication bypass attack on a web application?

- ☒ Allowing weak session management
- ☐ Accepting unencrypted connections over TCP 80
- ☐ Authenticating with alphabetical passwords
- ☐ Accommodating outdated browser connections

全82問中18問目

次のうち、Webアプリケーションに対する認証バイパス攻撃に特有の脆弱性はどれですか？

- ☒ 脆弱なセッション管理を許可する
- ☐ TCPポート80経由で暗号化されていない接続を受け入れる
- ☐ 英字パスワードによる認証
- ☐ 古いブラウザ接続への対応

☒ その通りです

ウェブアプリケーションでは、通常、セッショントークンを含むセキュアなクッキーをユーザーに提供します。ユーザーのブラウザは、確立された認証セッションを示すために、リクエストごとにそのクッキーをサーバーに送信します。脆弱なセッション管理とは、クッキーが安全でない、または攻撃者がその内容を推測できる場合、あるいはウェブアプリケーションの実装でセッション管理が全く使用されていない場合を指します。脆弱なセッション管理の脆弱性が存在する場合、攻撃者はウェブアプリケーションの認証をより容易に回避できます。認証バイパスは、パスワードクラッキングや推測/ファジングとは関係ありません。これは、ユーザーを適切に認証していないウェブアプリケーションのリクエストを悪用するものです。

Question 19 of 82

Who has the ultimate responsibility to ensure an ICS meets security requirements in the field?

- ☐ Integrators
- ☐ Asset owners
- ☐ Government entities
- ☐ Vendor partners

全82問中19問目

現場においてICSがセキュリティ要件を満たしていることを保証する最終的な責任は誰にあるのでしょうか？

- ☐ インテグレーター
☒ 資産所有者
☒ 政府機関
☐ ベンダーパートナー

✖ あなたは間違っています

資産所有者／運用者は、効率的で政府規制に適合するシステムを設計・構築するために、ベンダーやシステムインテグレーターと協力する必要があります。近年、セキュリティは世間の注目を集めるようになり、政府規制当局による監視も強化されています。現在、資産所有者／運用者は、運用するシステムにセキュリティが組み込まれるようにする責任を負っています。

Question 20 of 82

What is being determined when multiplying an asset value to the exposure factor (EF) percentage?

- ☐ Annualized rate occurrence
☐ Single loss expectancy
☐ NERC CIP fine
☐ Annualized loss expectancy

全82問中20問目

資産価値にエクスポージャー係数（EF）のパーセンテージを乗じることで、何が決定されるのでしょうか？

- ☐ 年間発生率
☒ 単一損失期待値
☐ NERC CIP罰金
☐ 年間損失期待値

✔ その通りです

SLEは、単一の事象に割り当てられる金額です。つまり、単一の事象によって組織が被る損失額です。エクスポージャーファクター（EF）は、脅威事象が資産に及ぼす損失の割合です。EFは、資産の損失率0～100%で表されます。その計算式は次のとおりです。単一損失期待値（SLE）＝資産価値×損失率（EF）

Question 21 of 82

Which of the following is the NTP hierarchical level where an atomic clock is found?

- ☐ Layer 7
- ☐ Stratum 0
- ☐ Stratum 15
- ☐ Layer 1

全82問中21問目

次のうち、原子時計が配置されているNTP階層レベルはどれですか？

- ☐ レイヤー7
- ☒ 層0
- ☐ 第15層
- ☐ レイヤー1

✔ その通りです

ストラタム0は、セシウムやルビジウムを用いた原子時計、GPS時計、その他の電波時計など、高精度な時刻計測装置を指します。これらは「基準時計」と呼ばれます。米国海軍天文台は、米国政府の用途向けに基準時刻信号を維持管理している組織の一例です。

Question 22 of 82

Which type of ICS component uses the fastest polling rate?

- ☐ Programmable logic controller
- ☐ Regional SCADA
- ☐ Site SCADA
- ☐ Engineering workstation

全82問中22問目

ICSコンポーネントの中で、最も高速なポーリングレートを使用するのはどのタイプですか？

☒ プログラマブルロジックコントローラ

☐ 地域SCADA

☐ サイトSCADA

☐ エンジニアリングワークステーション

☒ その通りです

ポーリングレートは、さまざまな種類のICSコンポーネントを区別するのに役立ちます。地域SCADAは数秒から数分と最も長いポーリングレートを持ち、一方、コントローラやフィールドデバイスは1秒未満のタイミングで計測するため、最も短いポーリングレートになります。

Question 23 of 82

Please examine the risk analysis values noted below. What is the calculated Annualized Loss Expectancy for the particular risk?

- ASSET VALUE: \$100
- SINGLE LOSS EXPECTANCY: \$60
- LIKELIHOOD: 0.15
- FREQUENCY: 5

☐ \$15

☐ \$300

☐ \$75

☐ \$45

全82問中23問目

下記のリスク分析値をご確認ください。当該リスクに対する年間損失期待値はいくらですか？

- 資産価値：100ドル
- 1回の損失予想額：60ドル
- 可能性: 0.15
- 頻度：5

- ☐ 15ドル
- ☐ 300ドル
- ☒ 75ドル
- ☒ 45ドル

✖ あなたは間違っています

年間損失期待値とは、特定の脅威によって生じる年間予想財務損失額のことで、この値は、3つの異なる計算によって算出されます。

- 単一損失期待値 = 資産価値 × 損失率
- 年間発生率 = 可能性 × 頻度
- 年間損失期待値 = 単一損失期待値 × 年間発生率

上記の値を用いてこれらの式を使用すると、以下に示すように年間損失期待値を計算できます。

- 単一損失期待値 = 60ドル（既知）
- 年間発生率 = 0.75（発生確率 (0.15) × 発生頻度 (5)）
- 年間損失期待値 = 45ドル（単一損失期待値（60ドル）× 年間発生率 (0.75)）

Question 24 of 82

Which is a characteristic of a Quantitative risk assessment that is not used in a Qualitative risk assessment?

- ☒ Vulnerability assessment
- ☐ Assessment of threat risk rating
- ☐ Determination of threat impact
- ☐ Loss computation

全82問中24問目

定量的リスク評価の特徴のうち、定性的リスク評価では用いられないものはどれですか？

- ☐ 脆弱性評価
- ☐ 脅威リスク評価
- ☐ 脅威の影響の判定
- ☒ 損失計算

✔ その通りです

定量化は、定量的リスク評価と定性的リスク評価の決定的な違いです。損失計算は一般的な定量化手法ですが、制御コストや脅威発生確率の計算なども定量的評価で用いられることがあります。その他の回答はどちらの評価方法でも使用されますが、定性的評価では数値ではなく、高／中／低といった主観的な評価に依拠します。

Question 25 of 82

The head of the Ackme IT department sent a directive stating that all company communication must use TLS in order to prevent third parties from modifying data without Ackme's knowledge. Which part of the C-I-A model is the head of IT concerned with?

- ☐ Confidentiality
- ☐ Availability
- ☐ Encryption
- ☒ Integrity

全82問中25問目

Ackme社のIT部門責任者は、第三者がAckme社の許可なくデータを改ざんすることを防ぐため、すべての社内通信にTLSを使用するよう指示を出しました。IT部門責任者はCIAモデルのどの部分に関心を持っているのでしょうか？

- ☐ 機密保持
- ☐ 可用性
- ☐ 暗号化
- ☒ 誠実さ

✔ その通りです

データの完全性とは、データが不正に改ざんされないという保証によって定義される。

Question 26 of 82

Which of the following describes the concept of Culture of Compliance?

- ☐ Utilization of compliance controls that ensure policies are effectively implemented and shortcomings are tracked and corrected
- ☐ Routine review of policies to ensure they are tracking with the current direction of the organization
- ☐ Beginning with leadership, an understanding of the importance of policies and support for them throughout the organization
- ☐ Use of Compliance Gap Assessments to measure issues in situations in which policies are not being followed

全82問中26問目

次のうち、コンプライアンス文化の概念を説明しているのはどれですか？

- ☐ 法令遵守管理を活用し、法令が効果的に実施され、不備が追跡・是正されることを保証する。
- ☐ 組織の現在の方向性と合致していることを確認するための定期的な方針の見直し
- ☒ リーダーシップから始まり、組織全体で方針の重要性を理解し、それを支持することが重要である。
- ☐ コンプライアンスギャップ評価を用いて、ポリシーが遵守されていない状況における問題点を測定する

✔ その通りです

これらはすべて、方針の採用と企業方針との整合性を促進する方法を説明しています。コンプライアンス文化とは、組織のリーダーシップによって推進され、組織全体で方針が広く受け入れられ、その重要性が理解される文化的な状態を指します。

Question 27 of 82

An RTOS buffer overflow vulnerability poses the most security risk to which of the following?

- ☐ Embedded system firmware
- ☐ Web applications that accept user input
- ☐ Historian database servers
- ☐ Switches with span ports

全82問中27問目

RTOSのバッファオーバーフローの脆弱性は、以下のうちどれに対して最も大きなセキュリティリスクをもたらしますか？

☒ 組み込みシステムファームウェア

- ☐ ユーザー入力を受け付けるWebアプリケーション
- ☐ 歴史データベースサーバー
- ☐ スパンポート付きスイッチ

☒ その通りです

組み込みシステムとは、特定のタスク向けに設計され、それらのタスクをサポートするように調整されたシステムです。RTOSは、組み込みデバイス上で動作するリアルタイムオペレーティングシステムであり、従来のコンピュータで使用するオペレーティングシステムのようなオーバーヘッドなしに機能を提供します。RTOSシステムでは、カーネル空間とユーザー空間が分離されていることはほとんどありません。組み込みシステムの脆弱性を発見した場合、攻撃者は権限昇格やその他の脆弱性の連鎖を必要とせずに、システムを完全に制御できる可能性が高くなります。

Question 28 of 82

What is a benefit of an integrated SIS over a traditional SIS?

- ☐ Increase in reliability
- ☐ Reduction in equipment costs
- ☐ Increase in system robustness
- ☐ Reduction in probability of safety event

全82問中28問目

統合型SISは、従来型SISに比べてどのような利点がありますか？

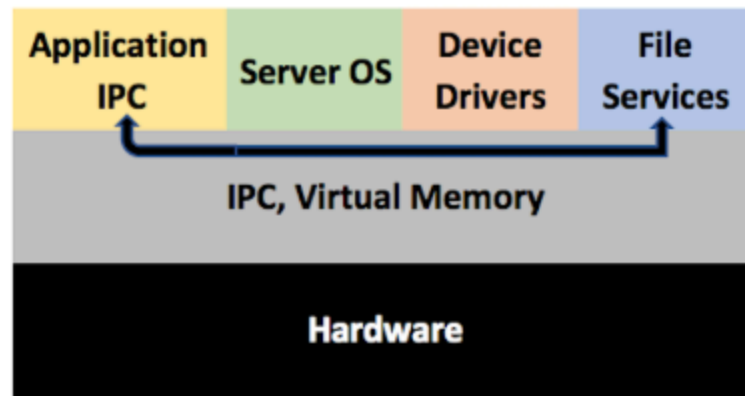
- ☐ 信頼性の向上
- ☒ 設備コストの削減
- ☐ システムの堅牢性の向上
- ☐ 安全事象発生確率の低減

☒ その通りです

統合型SISは配線が少なく、追加のハードウェアも不要です。

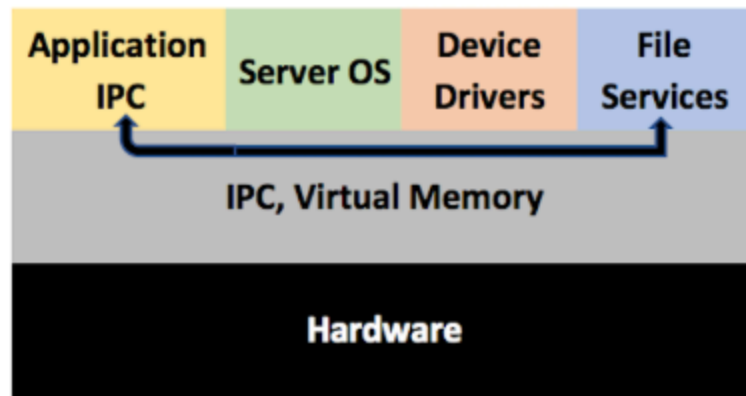
Question 29 of 82

The diagram below demonstrates the operation of which of the following?



- ☐ Microkernel OS
- ☐ Virtual machine hypervisor
- ☐ Virtual machine guest
- ☐ Monolithic kernel OS

以下の図は、次のうちどれの動作を示していますか？



☒ マイクロカーネルOS

- ☐ 仮想マシンハイパーバイザー
- ☐ 仮想マシンゲスト
- ☐ モノリシックカーネルOS

☒ その通りです

モノリシックカーネル（例えば、Windows OSのフルインストール）とは異なり、マイクロカーネルは、基本的なプロセス間通信（IPC）、仮想メモリ、スケジューリングといった機能を担うことが多い。モノリシックOSではカーネルレベルで行われるようなその他の一般的な操作は、マイクロカーネルOSではユーザーランドプログラムとして実行され、ドライバやファイル管理などの処理を担当する。

Question 30 of 82

The incident response team is called to investigate ICS workstations found to be running unauthorized port scans against other systems on the network. Shortly after being scanned, some of those systems start to run port scans against additional network hosts. There is apparently no user interaction at the time of infection. What type of malware matches the described behavior?

- ☐ Backdoor
- ☐ Worm
- ☐ Rootkit
- ☐ Trojan

全82問中30問目

インシデント対応チームは、ネットワーク上の他のシステムに対して不正なポートスキャンを実行しているICSワークステーションの調査を依頼された。スキャン後もなく、これらのシステムの一部は、さらに他のネットワークホストに対してポートスキャンを開始した。感染時にユーザーによる操作は一切なかったようだ。このような挙動を示すマルウェアの種類は何か？

- ☐ 裏口
- ☒ **ワーム**
- ☐ ルートキット
- ☐ トロイの木馬

✔ その通りです

ワームは、ユーザーの操作を必要とせずに自己複製するマルウェアの一種です。例えば、Confickerワーム感染は、MS-086 DCOM/RPCの脆弱性を悪用しました。このワームは工場のDCSシステムに侵入し、駆除が困難でした。

Question 31 of 82

Which of the following is the term that describes the process condition where a hazardous safety, health, and environmental event cannot occur?

- ☐ Recovery mode
- ☐ Fail state
- ☐ Restore mode
- ☒ **Safe state**
- ☐ Ready state

全82問中31問目

危険な安全、健康、環境事象が発生しないプロセス状態を表す用語は、次のうちどれですか？

- ☐ リカバリーモード
- ☐ 障害状態
- ☐ 復元モード
- ☒ **安全な状態**
- ☐ 準備完了状態

✔ その通りです

安全計装システム（SIS）は、特に重要なプロセスシステムで使用される、設計されたハードウェアとソフトウェアの制御システムから構成されます。重要なプロセスシステムとは、稼働中に運用上の問題が発生した場合、安全、健康、環境（SH&E）への悪影響を回避するために、システムを安全な状態にする必要があるシステムを指します。

安全状態とは、プロセスが稼働中か停止中かを問わず、危険な安全衛生環境事象が発生しないようなプロセス状態のことです。安全状態は、適切な時期に、すなわち「プロセス安全時間」内に達成されなければなりません。

Question 32 of 82

Compare the ACLs from June and July listed below. Which of the following changes should be investigated further?

*****Firewall01--June*****

```
access-list inbound permit tcp any host 10.10.10.220 eq www
access-list inbound permit tcp host 10.10.33.66 host 10.10.10.16 eq 1433
access-list inbound permit udp host 10.10.33.66 host 10.10.10.16 eq 1433
access-list inbound permit tcp any host 10.10.10.252 eq 8080
access-list inbound permit tcp any host 10.10.10.252 eq ssh
access-list inbound permit tcp any host 10.10.10.252 eq https
access-list inbound permit tcp any host 10.10.10.4 eq www
access-list inbound permit tcp any host 10.10.10.252 eq smtp
access-list inbound permit tcp host 10.10.207.91 host 10.10.10.17 eq ssh
access-list inbound permit tcp any host 10.10.10.100 eq 81
```

*****Firewall01--July*****

```
access-list inbound permit tcp any host 10.10.10.220 eq 80
access-list inbound permit tcp host 10.10.33.66 host 10.10.10.16 eq 1433
access-list inbound permit udp host 10.10.33.66 host 10.10.10.16 eq 1433
access-list inbound permit tcp any host 10.10.10.252 eq 8080
access-list inbound permit tcp any host 10.10.10.252 eq ssh
access-list inbound permit tcp any host 10.10.10.252 eq 443
access-list inbound permit tcp any host 10.10.10.4 eq www
access-list inbound permit tcp any host 10.10.10.252 eq 25
access-list inbound permit tcp host 10.10.207.91 host 10.10.10.17 eq 22
access-list inbound permit tcp host 10.10.207.91 host 10.10.10.17 eq 23
access-list inbound permit tcp any host 10.10.10.100 eq 81
```

- ☐ 10.10.207.91 can connect to 10.10.10.17 by 22
- ☐ 10.10.207.91 can connect to 10.10.10.17 by 23
- ☐ Any host can connect to 10.10.10.220 by port 80
- ☐ Any host can connect to 10.10.10.252 by port 443

下記に記載されている6月と7月のACLを比較してください。以下の変更点のうち、さらに調査すべきものはどれですか？

*****Firewall101--June*****

```
access-list inbound permit tcp any host 10.10.10.220 eq www
access-list inbound permit tcp host 10.10.33.66 host 10.10.10.16 eq 1433
access-list inbound permit udp host 10.10.33.66 host 10.10.10.16 eq 1433
access-list inbound permit tcp any host 10.10.10.252 eq 8080
access-list inbound permit tcp any host 10.10.10.252 eq ssh
access-list inbound permit tcp any host 10.10.10.252 eq https
access-list inbound permit tcp any host 10.10.10.4 eq www
access-list inbound permit tcp any host 10.10.10.252 eq smtp
access-list inbound permit tcp host 10.10.207.91 host 10.10.10.17 eq ssh
access-list inbound permit tcp any host 10.10.10.100 eq 81
```

*****Firewall101--July*****

```
access-list inbound permit tcp any host 10.10.10.220 eq 80
access-list inbound permit tcp host 10.10.33.66 host 10.10.10.16 eq 1433
access-list inbound permit udp host 10.10.33.66 host 10.10.10.16 eq 1433
access-list inbound permit tcp any host 10.10.10.252 eq 8080
access-list inbound permit tcp any host 10.10.10.252 eq ssh
access-list inbound permit tcp any host 10.10.10.252 eq 443
access-list inbound permit tcp any host 10.10.10.4 eq www
access-list inbound permit tcp any host 10.10.10.252 eq 25
access-list inbound permit tcp host 10.10.207.91 host 10.10.10.17 eq 22
access-list inbound permit tcp host 10.10.207.91 host 10.10.10.17 eq 23
access-list inbound permit tcp any host 10.10.10.100 eq 81
```

- ☐ 10.10.207.91 は22 を介して 10.10.10.17 に接続できます
- ☒ 10.10.207.91 は23 を介して 10.10.10.17 に接続できません
- ☐ どのホストもポート80経由で10.10.10.220に接続できます。
- ☐ どのホストもポート443経由で10.10.10.252に接続できます。

その通りです

10.10.207.91 は、telnet (ポート 23) 経由で 10.10.10.17 に接続できるようになりました。SSH (ポート 22) 経由では、これまで接続可能でした。任意のホストは、www トラフィックであるポート 80 を介して 10.10.10.220 に接続できます。このルールは変更されていません。任意のホストは、https トラフィックであるポート 443 を介して 10.10.10.252 に接続できます。このルールも変更されていません。

Question 33 of 82

Which of the following message security properties does a digital signature provide in the context of public-key cryptography?

- ☐ Integrity and non-repudiation
- ☐ Confidentiality and integrity
- ☐ Non-repudiation and confidentiality
- ☒ Integrity and availability

全82問中33問目

公開鍵暗号方式において、デジタル署名は以下のメッセージセキュリティ特性のうちどれを提供しますか？

- ☒ 誠実さと否認の禁止
- ☐ 機密保持と誠実性
- ☐ 否認防止および機密保持
- ☒ 誠実さと可用性

× あなたは間違っています

公開鍵暗号に基づくデジタル署名は、メッセージが改ざんされていないことを証明し、送信者／作成者の身元を確認するため、完全性と否認防止の両方を保証します。署名に使用された公開鍵に対応する秘密鍵を保有する者のみが、このメッセージを作成できたはずですが、デジタル署名はメッセージの機密性を保証するものではありません。暗号化せずに送信された平文メッセージに付加することも可能です。また、一連のメッセージに累積署名を使用しない限り、メッセージが送信中に検出されずに失われる可能性があるため、可用性も保証されません。

Question 34 of 82

Which of the following describes an effective policy?

- ☐ Achievable and measurable directive
- ☐ Best practice based instruction
- ☐ Risk and compliance based guidance
- ☐ Organizational values statement

全82問中34問目

次のうち、効果的な政策を説明しているのはどれですか？

- ☒ 達成可能かつ測定可能な指示
- ☐ ベストプラクティスに基づいた指導
- ☒ リスクとコンプライアンスに基づくガイダンス
- ☐ 組織の価値観に関する声明

× あなたは間違っています

政策とは、特定の目標に向かって進むための明確な決定を示す指示である。政策自体は効果的かつ現実的であり、達成可能な安全保障目標を持つべきである。

Question 35 of 82

What is a recommendation for setting up a secure ICS network architecture?

- ☐ Deploy and manage virtualization technologies in Purdue level 3 separately from that of the enterprise
- ☐ Put patch management servers for control systems in the ICS DMZ
- ☒ Limit each Purdue level to having a single subnet in a non-SCADA environment
- ☐ Place workstations having access to the Internet and corporate email at Purdue level 3
- ☐ Place writable aggregate plant historians in the ICS DMZ

全82問中35問目

安全なICSネットワークアーキテクチャを構築するための推奨事項は何ですか？

- ☒ Purdueレベル3の仮想化技術を、エンタープライズレベルとは別に展開および管理する。
- ☐ 制御システムのパッチ管理サーバーをICS DMZに配置する
- ☒ 非SCADA環境では、各パーデュレベルに単一のサブネットのみを持たせるように制限する。
- ☐ インターネットと社内メールにアクセスできるワークステーションをパーデュ大学3階に設置する。
- ☐ 書き込み可能な集合プラント履歴データをICS DMZに配置する

✖ あなたは間違っています

パッチサーバーをICS DMZ に配置すると、パッチ適用のためDMZ ファイアウォールに多数の穴を開ける必要が生じます。このため、サーバーをレベル3内に配置することをお勧めします。Purdue レベル3で仮想化技術を使用する場合は、エンタープライズの仮想化技術とは別に展開および管理する必要があります。ネットワークはPurdue レベルごとに編成する必要がありますが、1つのPurdue レベルには複数のサブネットを含めることができます。インターネットおよび企業メールにアクセスできるシステムはレベル4より深く配置すべきではなく、下位レベルのスタッフがこのデータにアクセスする必要がある場合は、レベル4マシンを割り当てる必要があります。制御システムのパッチ管理サーバーはPurdue レベル3に配置する必要があります。ICS DMZ に配置すると、ファイアウォールルールが安全でない可能性があります。集約プラント履歴はPurdue レベル3に配置し、必要に応じてICS DMZ 内の読み取り専用履歴に複製する必要があります。

Question 36 of 82

Which level is the most granular for applying GPO policies in Active Directory?

- ☐ Workgroup
- ☐ Domain
- ☐ Organizational Unit
- ☐ Forest

全82問中36問目

Active DirectoryでGPOポリシーを適用する際に、最も詳細なレベルはどれですか？

- ☐ ワーキンググループ
- ☐ ドメイン
- ☒ 組織単位
- ☐ 森

✔ その通りです

ベストプラクティスとしては、ドメインレベルではなく組織単位レベルでGPOを管理するのが一般的です。これは、すべてのシステムに同じGPOを適用できるドメインはごく少数であるため、OUの方がドメインよりも粒度が細かいからです。フォレストは、AD構造の中で最も粒度の小さい単位です。ワークグループはADとGPOをサポートしていません。GPOをユーザーアカウントに直接適用することはできません。

Question 37 of 82

You are being asked to write a utility script that runs once a month and retrieves several files from the /etc directory on all of your Linux-based embedded devices for centralized analysis. Which IT-related process does this script support?

- ☐ Configuration monitoring
- ☐ Log collection and audit
- ☐ Patch management
- ☐ Baseline image testing

全82問中37問目

あなたは、毎月1回実行され、すべてのLinuxベースの組み込みデバイスの/etcディレクトリから複数のファイルを取得して一元的に分析するユーティリティスクリプトを作成するよう依頼されています。このスクリプトは、どのIT関連プロセスをサポートしますか？

- ✔ 構成監視
- ✘ ログ収集と監査
- ☐ パッチ管理
- ☐ ベースライン画像検査

✘ あなたは間違っています

Linuxでは、/etcディレクトリは設定ファイル用に予約されており、バイナリやログデータは含まれていないため、問題のスクリプトはデバイスの現在の設定のみを取得できます。設定監視プロセスの一環として、このデータは分析され、現在の設定が期待値に準拠しており、展開以降変更されていないことが確認されます。ログ収集とパッチ管理を参照する2つの回答は、/etcには設定ファイルしか含まれていないため誤りです。「ベースラインイメージのテスト」という回答も、質問文ではデバイスから中央の場所への読み取り専用のデータフローについて説明されており、ベースラインデータがデバイスにプッシュされることについては何も言及されていないため誤りです。

Question 38 of 82

What can be done to get malicious code to execute when a computer starts up?

- ☐ Use pagefile.sys to launch it
- ☐ Inject it into RAM memory
- ☐ Use filesystem slack space to store it
- ☐ Place it in the boot sector
- ☐ Use the BIOS to launch a script that calls it

全82問中38問目

コンピュータの起動時に悪意のあるコードを実行させるには、どのような方法がありますか？

- ☐ pagefile.sys を使用して起動します。
- ☐ RAMメモリに注入する
- ☐ ファイルシステムの空き領域を使用して保存します。
- ☒ ブートセクターに配置してください
- ☐ BIOSを使用して、それを呼び出すスクリプトを起動します。

× あなたは間違っています

BIOSはスクリプトの呼び出しには使用できず、pagefile.sysは物理メモリがいっぱいになった場合にのみアクセスされ、RAMメモリはマシンの電源サイクルごとにクリアされます。また、悪意のあるコードはスラック領域に格納できますが、自動的に起動することはありません。ブートセクタ内のコードは、OSが起動するたびに実行されます。

Question 39 of 82

Which layer in the OSI model is responsible for handling the sequencing of data segments?

- ☐ Presentation
- ☐ Network
- ☐ Transport
- ☐ Data Link

全82問中39問目

OSIモデルのどの層がデータセグメントの順序付けを担当していますか？

- ☐ プレゼンテーション
- ☐ ネットワーク
- ☒ 輸送
- ☐ データリンク

✔ その通りです

トランスポート層は、ネットワーク層からのパケットとやり取りし、パケットをシーケンス化して送信の準備を行います。TCPの場合、エンドツーエンドの信頼性の高い接続を保証し、送信のためにパケットをセグメントにシーケンス化する処理も行います（UDPは信頼性の高い送信を保証せず、パケットはセグメントではなくデータグラムとして送信されます）。ネットワーク層は、複数のネットワークセグメントの接続を処理し、異なるネットワークセグメント上のシステムがどのように互いを検出して通信するかを記述します。データリンク層は、ネットワークの物理的な部分（ケーブルと電気信号）と抽象的な部分（パケットとデータストリーム）を接続します。プレゼンテーション層は、接続の一方の側から送信されたデータが、もう一方の側にとって有用な形式で受信されるようにします。

Question 40 of 82

Where should an in-line, transparent, ICS firewall be placed on a network?

- ☐ At a network boundary
- ☐ At a DMZ boundary
- ☐ Between HMI devices
- ☐ In front of a controller

全82問中40問目

インライン型で透過的なICSファイアウォールは、ネットワーク上のどこに配置すべきでしょうか？

- ☐ ネットワーク境界において
- ☐ DMZの境界で
- ☐ HMIデバイス間
- ☒ コントローラーの前で

✔ その通りです

これらのファイアウォールは、ICSアーキテクチャの下位レベル（レベル2以下）で使用され、コントローラや安全システムPLCへのトラフィックをフィルタリングします。保護対象機器と直列に接続する必要があります。

Question 41 of 82

What is a characteristic of Windows Group Policy Objects (GPOs)?

- ☐ Requires computer be rebooted to apply
- ☐ Deployed automatically using Active Directory
- ☐ Overwritten by Local Security Policies

全82問中41問目

Windowsグループポリシーオブジェクト（GPO）の特徴は何ですか？

- ☐ 適用するにはコンピュータの再起動が必要です
- ☒ **Active Directoryを使用して自動的にデプロイされます**
- ☐ ローカルセキュリティポリシーによって上書きされます

☒ **その通りです**

グループ ポリシーを使用してセキュリティ テンプレートを展開するには、対象のマシンがドメインに参加している必要があります。GPO は、Windows Active Directory を使用して自動的に展開できます。グループ ポリシー オブジェクトはローカル セキュリティ ポリシーよりも優先され、gpmmc.msc や gpedit.msc などのツールを使用して管理できます。secedit.exe は、Active Directory ドメインに参加していないマシンのセキュリティ ポリシーを管理するためのツールです。GPO は、起動時、ログオン時、および 90 ～ 120 分ごとに適用されます。

Question 42 of 82

An attacker is able to adjust settings on a GPO that will be pushed out across all workstations. What is the maximum amount of time before workstations will download the malicious GPOs?

- ☐ 60 minutes
- ☐ 90 minutes
- ☐ 30 minutes
- ☒ **120 minutes**

全82問中42問目

攻撃者は、すべてのワークステーションに展開されるGPOの設定を変更できます。ワークステーションが悪意のあるGPOをダウンロードするまでの最大時間はどれくらいですか？

- ☐ 60分
- ☐ 90分
- ☐ 30分
- ☒ **120分**

☒ **その通りです**

ドメイン内のマシンは、90分から120分ごとにグループポリシーオブジェクト（GPO）が変更されていないか自動的に確認し、変更されている場合は新しいGPOをダウンロードするように構成されています。上限が120分であるため、マシンが再度確認するまでにかかる最大時間は120分です。

Question 43 of 82

When in the recovery stage of an Incident Response, who determines when a system is put back into production?

- ☐ Security team
- ☐ System owner
- ☐ Incident handler
- ☐ Network manager

全82問中43問目

インシデント対応の復旧段階において、システムを本番環境に復帰させるタイミングは誰が決定するのでしょうか？

- ☐ セキュリティチーム
- ☒ システムオーナー
- ☐ インシデントハンドラー
- ☐ ネットワークマネージャー

✔ その通りです

システムをいつ運用再開するかは、システム所有者が決定しなければなりません。担当者は助言や可能な限りのサポートを提供できますが、最終的にシステムをオンラインに戻すかどうかの決定権は、システム所有者または管理者にあります。

Question 44 of 82

A working group consisting of top subject matter experts from at least a dozen organizations in the industry is developing a security document that details what vendors must do if they are to provide field widgets that are reasonably secure. If this document is successful in being adopted, many vendors of field widgets will need to comply with it. Which type of document is the working group developing?

- ☐ Guideline
- ☐ Standard
- ☐ Policy
- ☐ Procedure

全82問中44問目

業界の少なくとも12の組織から集まった一流の専門家で構成されるワーキンググループが、ベンダーが適切なセキュリティを備えたフィールドウィジェットを提供するために遵守すべき事項を詳述したセキュリティ文書を作成しています。この文書が採用されれば、多くのフィールドウィジェットベンダーがこれに準拠する必要が生じます。ワーキンググループが作成している文書はどのような種類のものなのでしょうか？

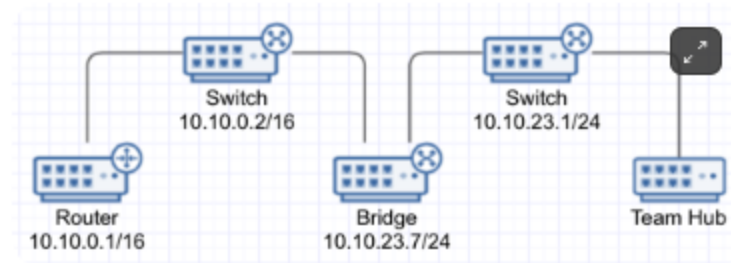
- ☒ ガイドライン
- ☒ 標準
- ☐ ポリシー
- ☐ 手順

✖ あなたは間違っています

規格は、高レベルかつ具体的なものになり得ます。関連性があり採用されている場合、多くの組織はその規格に「準拠」することが求められます。規格には認証が付随することもあります。組織や製品は認証を受けるか、準拠しているとみなされます。手順とは、非常に具体的なタスクを繰り返し実行するための段階的な指示です。ポリシーは、より高レベルの記述です。ガイドラインは、ポリシーと手順の中間に位置し、より曖昧で一般的なガイダンスを提供します。

Question 45 of 82

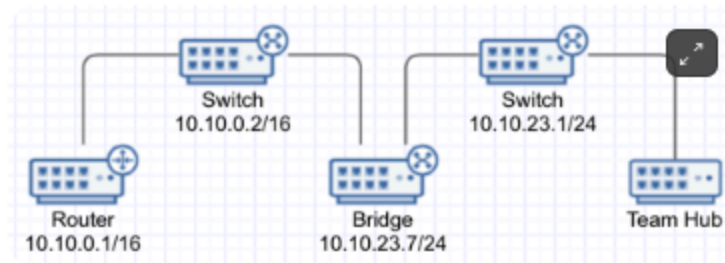
Observe the devices below; which network device will drop Layer 2 broadcast traffic?



- ☐ Bridge
- ☐ Switch
- ☐ Router
- ☐ Hub

全82問中45問目

以下のデバイスを観察してください。どのネットワークデバイスがレイヤ2ブロードキャストトラフィックをドロップしますか？



- ☐ 橋
- ☐ スイッチ
- ☒ ルーター
- ☐ ハブ

✔ その通りです

ルーターはレイヤー3で動作し、パケット転送時にIPアドレスを参照します。ルーターはデフォルトではMACレベル（レイヤー2）のトラフィックをすべて破棄します。スイッチとブリッジはMACレベルの情報を使用してトラフィックを切り替えます。ハブは、1つのポートで受信したトラフィックを、稼働中のすべてのポートに単純に中継します。

Question 46 of 82

Which of the following contains the logic and parameters for Programmable Logic Controllers (PLCs)?

- ☐ Historian
- ☐ Front End Processor
- ☐ Human Machine Interface
- ☐ Project Files

全82問中46問目

次のうち、プログラマブルロジックコントローラ（PLC）のロジックとパラメータが含まれているのはどれですか？

- ☐ 歴史家
- ☒ フロントエンドプロセッサ
- ☐ ヒューマンマシンインターフェース
- ☒ プロジェクトファイル

✖ あなたは間違っています

PLC が実行するタスクはハードコーディングされていません。名前が示すように、PLC の機能はプログラムで設定できます。エンジニアリングワークステーションによく保存されているプロジェクトファイルには、制御システム、ネットワークアーキテクチャ、構成、および PLC のロジックとパラメータの詳細が含まれています。そのため、攻撃者にとって格好の標的となります。ヒューマンマシンインターフェースは、オペレータにデータを提供しますが、自動化されたプロセスのロジックは含まれていません。ヒストリアンにはイベントログが含まれており、多くの場合 SQL データベースに保存されます。フロントエンドプロセッサは、RTU (リモートターミナルユニット) と管理システム間の通信を監視します。

Question 47 of 82

Which factors are compared in a security Cost Benefit Analysis?

- ☐ Cost of breach and value of the lost revenue flow
- ☐ Cost of a business process and value produced by that process
- ☐ Cost of controls and value of the reduced risk
- ☐ Reputation cost and value of the protected asset

全82問中47問目

セキュリティの費用対効果分析では、どのような要素が比較されますか？

- ☐ 侵害のコストと失われた収益フローの価値
- ☐ ビジネスプロセスのコストと、そのプロセスによって生み出される価値
- ☒ 管理コストとリスク低減の価値
- ☐ 評判コストと保護対象資産の価値

✔ その通りです

セキュリティ対策を実施する際、費用便益分析では、セキュリティ対策のコストと、それによって得られるリスク軽減効果を比較します。評判コストは、セキュリティインシデントで発生するものであり、企業の資産価値とは無関係であるため、費用便益分析の対象にはなりません。収益損失額は、侵害コストに含まれる要素であり、どちらも損失（コスト）です。ICSのコストと、ICSが生み出す価値は、ICSへの初期投資を裏付ける費用便益分析を構成します。

Question 48 of 82

An attack that modifies data in an ICS is a violation of which information security concept?

- ☒ Integrity
- ☐ Confidentiality
- ☐ Availability
- ☐ Non-repudiation

全82問中48問目

ICS内のデータを改ざんする攻撃は、どの情報セキュリティ概念に違反するでしょうか？

- ☒ 誠実さ
- ☐ 機密保持
- ☐ 可用性
- ☐ 否認禁止

✔ その通りです

完全性制御は情報の改ざんを防止するため、予期せずデータを変更できる攻撃は完全性に対する攻撃となります。機密性とは、権限のある者のみがデータにアクセスできるようにすることです。可用性とは、必要なときにデータにアクセスできることを意味します。否認防止とは、ある人物が何らかの行動をとったことを否定できないようにすることです。

Question 49 of 82

What communication method should an incident response team avoid using to discuss an active incident?

- ☐ Cell phone
- ☐ In person meeting
- ☐ Voice over IP
- ☐ Walkie-talkie

全82問中49問目

インシデント対応チームが、発生中のインシデントについて話し合う際に避けるべきコミュニケーション方法はどれですか？

- ☐ 携帯電話
- ☐ 対面での会議
- ☒ VoIP (Voice over IP)
- ☐ トランシーバー

✔ その通りです

インシデント対応担当者は極度のプレッシャーにさらされる可能性があります。例えば、ネットワークシステム全体を感染させ、事実上使用不能にしてしまうワームを考えてみてください。これが、インシデント対応チームがVoIPに頼ってはならない理由の一つです。VoIPを導入している場合は、携帯電話、トランシーバー、またはその他のバックアップ通信手段の使用を検討してください。

Question 50 of 82

Which device can be used to prevent a MODBUS write command from being executed on a PLC where only read commands are expected?

- ☐ Data diode
- ☐ Packet-filtering firewall
- ☐ Application-layer firewall
- ☐ Network intrusion detection sensor

全82問中50問目

読み取りコマンドのみが想定されるPLCで、MODBUS書き込みコマンドが実行されないようにするには、どのデバイスを使用すればよいですか？

- ☐ データダイオード
- ☐ パケットフィルタリングファイアウォール
- ☒ アプリケーション層ファイアウォール
- ☐ ネットワーク侵入検知センサー

✔ その通りです

アプリケーションファイアウォール（「次世代ファイアウォール」とも呼ばれる）は、アプリケーションレベルでプロトコルを解釈し、パケットの値と内容に基づいて判断を下すことができます。アプリケーションファイアウォールのルールは、定義された範囲外の値を含むトラフィックを破棄するように設定できます。パケットフィルタリングファイアウォールは、送信元および宛先IPアドレスやポートなど、パケットのネットワーク層およびトランスポート層ヘッダーに含まれる情報に基づいて判断を下します。

Question 51 of 82

How are Microsoft security templates stored?

- ☐ Plaintext file
- ☐ XML file
- ☐ Base64 encoded
- ☐ Proprietary format based on JSON

全82問中51問目

Microsoftのセキュリティテンプレートはどのように保存されますか？

- ☒ プレーンテキストファイル
- ☐ XMLファイル
- ☐ Base64エンコード
- ☐ JSONに基づいた独自のフォーマット

✔ その通りです

Microsoft セキュリティ テンプレートは、数百ものセキュリティ設定を保存できるプレーンテキスト構成ファイルです。メモ帳などのテキストエディタで手動で編集することもできますが、MMC スナップインの「セキュリティ テンプレート」を使用する方がはるかに安全で簡単です。

Question 52 of 82

If the CISO needs to determine the maximum tolerable downtime (MTD) for any given system, she will need to request which of the following?

- ☐ Plan Inter-dependencies
- ☐ Business Impact Analysis
- ☐ Business Continuity Plan
- ☐ Disaster Recovery Plan

全82問中52問目

CISOが特定のシステムにおける最大許容ダウンタイム（MTD）を決定する必要がある場合、以下のうちどれを要求する必要があるでしょうか？

- ☐ 相互依存関係を計画する
- ☒ ビジネス影響分析
- ☐ 事業継続計画
- ☐ 災害復旧計画

✔ その通りです

事業影響度分析（BIA）は、許容可能な最大ダウンタイムを決定するために策定されます。事業継続計画および復旧計画は、その目的で使用されるものではありません。また、計画間の依存関係も、最大許容ダウンタイム（MTD）の計算には使用されません。

Question 53 of 82

Which of the following factors increases the system call efficiency of a real-time operating system?

- ☐ The OS is embedded
- ☐ The system denies hardware interrupts
- ☐ The kernel and user space is not likely to be separated
- ☐ The platform is solid state

全82問中53問目

リアルタイムオペレーティングシステムのシステムコール効率を高める要因は次のうちどれですか？

- ☐ OSは組み込まれています
- ☐ システムはハードウェア割り込みを拒否します
- ☒ カーネル空間とユーザー空間は分離されない可能性が高い
- ☐ プラットフォームはソリッドステートです

✔ その通りです

RTOS上で動作するプロセスは、システムコール効率が高く、割り込みを無効化したり、その他の方法で環境を管理したりすることができます。これは、RTOSシステムではカーネル空間とユーザー空間が分離されていないためです。RTOSではハードウェア割り込みが禁止されているわけではなく、実際にはハードウェア割り込みの処理はRTOSの重要な機能です。システムが組み込みシステムであるという事実だけでは、システムコール効率が必ずしも向上するわけではありません。むしろ、組み込みシステムでRTOSを使用することによって、システムコール効率が向上するのです。

Question 54 of 82

The IEEE 802.1x standard defines which of the following?

- ☐ Subnet roaming
- ☐ Wireless communication
- ☐ Authentication
- ☐ Modulation
- ☐ Frequency hopping

全82問中54問目

IEEE 802.1x規格では、次のうちどれが定義されていますか？

- ☐ サブネットローミング
- ☐ 無線通信
- ☒ 認証
- ☐ 変調
- ☐ 周波数ホッピング

✖ あなたは間違っています

なりすまし攻撃から保護するためには、アクセスポイントに対するユーザーの認証と、ユーザーに対するアクセスポイントの認証を行う仕組みが必要です。これは、IEEE 802.1Xネットワーク認証プロトコルと、EAP/TLS、PEAP、TTLSなどの相互認証をサポートする拡張認証プロトコルを使用することで実現できます。

Question 55 of 82

Corporate cyber security policies within an organization should be treated in which of the following ways for ICS environments?

- ☐ Implemented as is
- ☐ Customized for ICS environments
- ☐ Only implemented in ICS test environments
- ☐ Never implemented in ICS environments

全82問中55問目

組織内の企業サイバーセキュリティポリシーは、ICS環境において、以下のどの方法で扱うべきでしょうか？

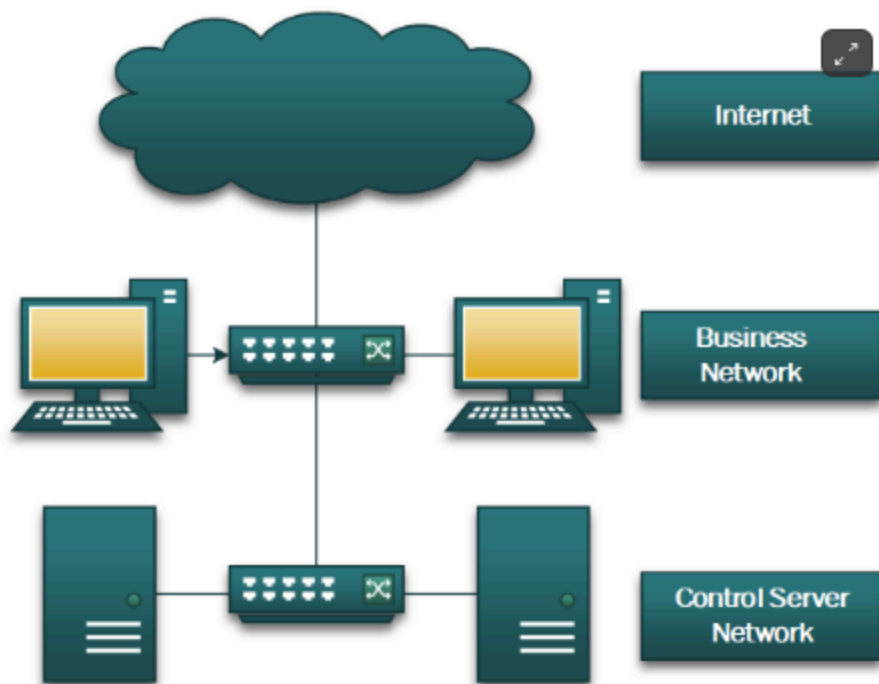
- ☐ 現状のまま実装
- ☒ ICS環境向けにカスタマイズ
- ☐ ICSテスト環境でのみ実装されています
- ☐ ICS環境では実装されたことがない

✔ その通りです

企業のサイバーセキュリティポリシーには多くの重要な要素が含まれているが、ICS環境に合わせてカスタマイズする必要がある。

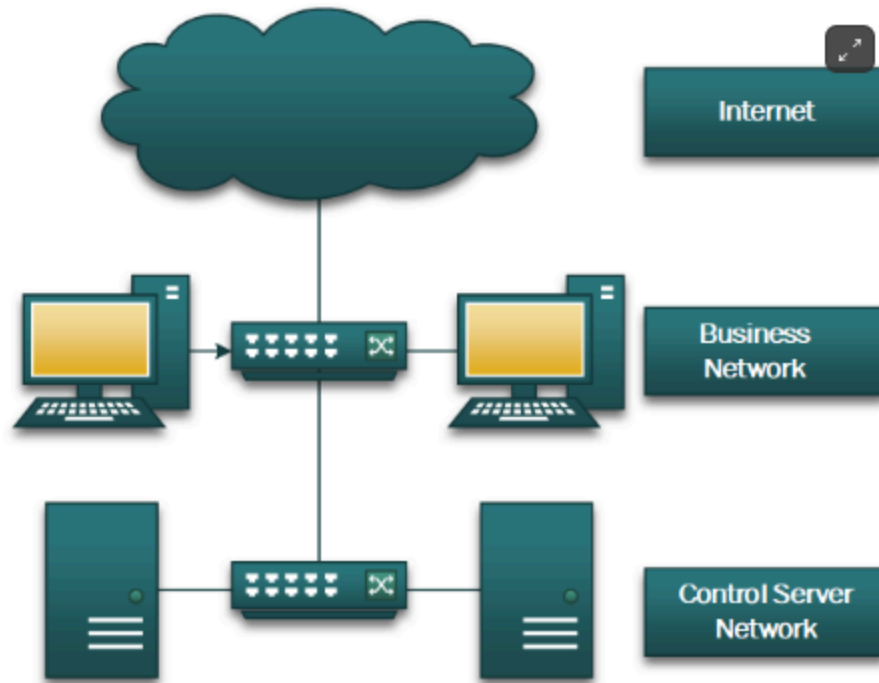
Question 56 of 82

Based on the network shown in the diagram, at minimum how many firewalls should be installed?



- ☐ 2
- ☐ 4
- ☐ 1
- ☐ 5
- ☐ 3

図に示されたネットワーク構成に基づく、最低限いくつのファイアウォールを設置する必要がありますか？



2
bdc2fab-abe4-47ec-a193-8505874050e7 (14266000)

- ☒ 2
- ☐ 4
- ☐ 1
- ☐ 5
- ☐ 3

✔ その通りです

各適用ゾーン間にはファイアウォールを設置し、不要なトラフィックや望ましくないトラフィックがゾーンを通過するのを防ぐ必要があります。図に示すように、これを実現するには、インターネットとビジネスネットワークの間に1つ目のファイアウォールを設置し、ビジネスネットワークと制御サーバーネットワークの間にもう1つのファイアウォールを設置する必要があります。

Question 57 of 82

Which of the following vulnerabilities could be tested for by using the string below?

```
<script>alert(String.fromCharCode(88,83,83))</script>
```

bdc2fab-abe4-47ec-a193-8505874050e7 (14266000)

- ☐ Cross Site Request Forgery
- ☐ Cross Site Scripting
- ☐ Control Signal Spoofing
- ☐ SQL injection

全82問中57問目

以下の文字列を使用することで、次のうちの脆弱性をテストできるでしょうか？

```
<script>alert(String.fromCharCode(88,83,83))</script>
```

- ☐ クロスサイトリクエストフォージェリ
- ☒ クロスサイトスクリプティング
- ☐ 制御信号の偽装
- ☐ SQLインジェクション

✔ その通りです

このスクリプトは、Webページがクロスサイトスクリプティングの脆弱性を持っているかどうかを判断するための、信頼性の高いシンプルなテストです。脆弱性がある場合、処理がこのスクリプトに到達した時点でページは警告を表示します。このスクリプトは、上記に挙げたその他の脆弱性についてはテストしません。

Question 58 of 82

Which asset would an ICS database rely on to perform third-party data translation?

- ☐ Intelligent Electronic Device (IED)
- ☐ OPC server
- ☐ HMI workstation
- ☐ PI server

全82問中58問目

ICSデータベースは、サードパーティデータの変換を実行するために、どの資産に依存するのでしょうか？

- ☐ インテリジェント電子機器 (IED)
- ☒ OPCサーバー
- ☐ HMIワークステーション
- ☐ PIサーバー

✔ その通りです

OPCサーバーは、ヒストリアンなどのサービス向けにサードパーティのデータ変換機能を提供することがよくあります。これにより、共通の通信プロトコルを共有していないアセット間でも通信が可能になります。PIシステムのようなヒストリアンの場合、OPCサーバーは、異なる形式で保存されたデータをPIシステムに供給し、データの表示や操作を可能にするために使用されます。

Question 59 of 82

Why may a Windows Application log fail to provide information about an application problem?

- ☐ The server administrator did not enable application logging
- ☐ The application developer did not specify logging information for the problem
- ☐ Application logging does not include a field for description
- ☐ The LOGEVENT.EXE process has stopped

全82問中59問目

Windowsアプリケーションログがアプリケーションの問題に関する情報を提供しないのはなぜですか？

- ☐ サーバー管理者がアプリケーションログを有効にしていませんでした
- ☒ アプリケーション開発者は、この問題に関するログ情報を指定していません。
- ☐ アプリケーションログには説明欄がありません
- ☐ LOGEVENT.EXE プロセスが停止しました

✔ その通りです

アプリケーションログには、開発者が定義および記述した条件が記録されます。開発者が問題のログ記録を選択しなかった場合、アプリケーションログにはエントリが表示されません。サーバー管理者が有効化する必要があるセキュリティログとは異なり、アプリケーションログはデフォルトで実行されます。LOGEVENT.EXE は、管理者が任意のログ情報をログに挿入するために使用できるオプションのコマンドラインツールであり、Windows のイベントログサービスのように自動的に問題をログに記録する機能はありません。アプリケーションログには、他のログと同じイベントフィールドが表示されます。

Question 60 of 82

What is a recommended guideline to follow when setting up a secure ICS network architecture?

- ☐ Move any onsite servers that communicate with the cloud for control systems to the ICS DMZ
- ☐ Place simple proxies in the ICS DMZ to keep them separate from systems in the control network
- ☐ Use the same jump hosts for employees and vendors
- ☒ Do not set up a trust between Active Directory domains on the control network and the Enterprise network

全82問中60問目

安全なICSネットワークアーキテクチャを構築する際に推奨されるガイドラインは何か？

- ☐ 制御システムのためにクラウドと通信するオンプレミスサーバーをすべて ICS DMZに移動します。
- ☐ シンプルなプロキシをICS DMZに配置して、制御ネットワーク内のシステムから分離します。
- ☐ 従業員とベンダーには同じジャンプホストを使用する
- ☒ コントロールネットワークとエンタープライズネットワーク上のActive Directoryドメイン間で信頼関係を構築しないでください。

✔ その通りです

安全な ICS ネットワーク アーキテクチャを構築するための推奨サイバーセキュリティ ガイドラインには、次のものが含まれます。1) 単純なプロキシは脆弱性を盲目的に通過させるため使用を避ける、2) エンタープライズとの信頼関係を持たない制御ネットワーク用の別の AD ドメインを設定する、3) 制御ネットワークのクラウドに接続するオンサイト サーバーを ICS DMZ に配置せず、別の DMZ に配置する、4) リモートで制御ネットワークにアクセスする各従業員またはベンダーは、それぞれのニーズに応じて異なるジャンプ ホストを使用する。

Question 61 of 82

When a HMI panel displays an alarm from a device's tamper sensor, which type of physical security control does it indicate?

- ☐ Detection
- ☐ Prevention
- ☐ Deterrence
- ☐ Response

全82問中61問目

HMIパネルにデバイスの改ざんセンサーからのアラームが表示された場合、それはどのようなタイプの物理的セキュリティ制御を示しているのでしょうか？

☒ 検出

☐ 防止

☐ 抑止力

☐ 応答

☒ その通りです

改ざん検知センサーは、セキュリティ侵害が発生した可能性を検知し、攻撃者を特定できます。物理的な抑止力は攻撃の試みの可能性を低減し、遅延機能は攻撃者の行動を遅らせます。物理的な認証レベルは、許可された担当者のみがエリアにアクセスできるようにする機能であり、対応機能は物理的な防御の最終段階であり、攻撃の結果として担当者と手順を発動します。

Question 62 of 82

Which of the following locations would be the Unix equivalent of \Program Files?

☐ /boot

☐ /dev

☐ /usr

☐ /root

☐ /etc

以下の場所のうち、Unix における \Program Files に相当するものはどれですか？

☐ /ブート

☐ /dev

☒ /usr

☐ /根

☐ /等

☒ その通りです

/usr はサードパーティ製アプリケーションファイルが格納されている場所です。/root はルートユーザーのホームディレクトリです。/etc は設定ディレクトリです。/dev はデバイスファイルです。/boot はカーネルファイルです。

全82問中62問目

Question 63 of 82

Which of the following can assist in implementing single sign-on authentication by using a ticketing system?

☐ Biometrics

☐ RADIUS

☐ Kerberos

☐ LDAP

全82問中63問目

チケットシステムを使用してシングルサインオン認証を実装する際に役立つのは、次のうちどれですか？

- ☐ 生体認証
- ☐ 半径
- ☒ ケルベロス
- ☐ LDAP

✔ その通りです

Kerberosはチケットシステムを使用してユーザーを認証します。LDAPは認証完了後に認可を提供します。RADIUSはチケットシステムを使用しません。

Question 64 of 82

What is the result of the following command?

```
wmic.exe /node:192.168.1.66 SHARE
```

- ☐ Create a shared drive on 192.168.1.66
- ☐ Connect to the share on 192.168.1.66
- ☐ List shared drives on 192.168.1.66
- ☐ Turn on share settings for 192.168.1.66

全82問中64問目

以下のコマンドを実行すると、どのような結果になりますか？

```
wmic.exe /node:192.168.1.66 SHARE
```

- ☐ 192.168.1.66 上に共有ドライブを作成します。
- ☐ 192.168.1.66 の共有フォルダに接続します。
- ☒ 192.168.1.66 の共有ドライブの一覧を表示します
- ☐ 192.168.1.66 の共有設定をオンにする

✔ その通りです

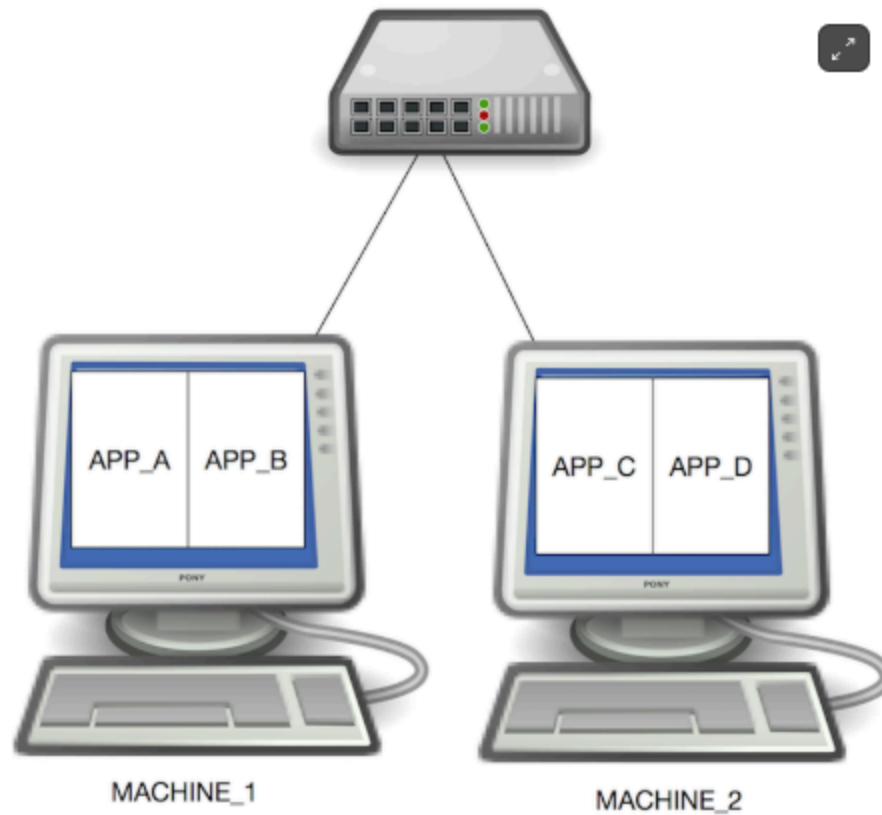
Wmic.exe は、変数を取得および設定することで Windows マシンを管理するために使用されます。この例では、マシン上のすべての共有の一覧が返されます。結果の表示方法は、たとえば次のように変更できます。

```
wmic.exe /node:192.168.1.66 SHARE list brief
```

出力は簡潔なリスト形式で表示されます。(リストなどの表示オプションは必須ではありません。)

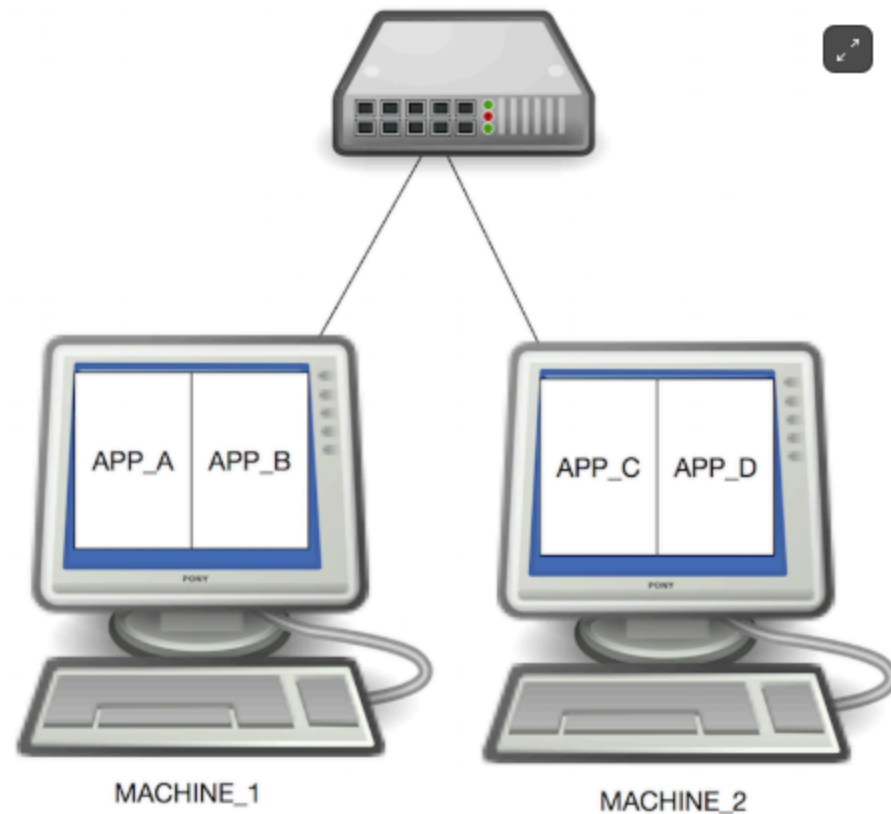
Question 65 of 82

An engineer has access to four web applications within an organization; App_A, App_B, App_C, and App_D. App_A and App_B are normally accessed from MACHINE_1, App_C and App_D are normally accessed from MACHINE_2. While using App_B a user had their cookie and session token stolen. Which statement most accurately describes how the attacker could impersonate the engineer while the stolen credentials are valid?



- ☐ Within App_B from any machine
- ☐ Within any of the four apps from MACHINE_1
- ☐ Within any of the four apps from any machine
- ☐ Within App_B from MACHINE_1

あるエンジニアは、組織内の4つのWebアプリケーション(App_A、App_B、App_C、App_D)にアクセスできます。App_AとApp_Bは通常MACHINE_1からアクセスされ、App_CとApp_Dは通常MACHINE_2からアクセスされます。App_Bを使用中に、ユーザーのCookieとセッショントークンが盗まれました。盗まれた認証情報が有効な状態で、攻撃者がエンジニアになりますことができる方法を最も正確に説明しているのは、次のうちどれですか。



- ☒ どのマシンからでもApp_B内で使用できます。
- ☐ MACHINE_1の4つのアプリのいずれか内で
- ☒ どのマシンからでも、4つのアプリのいずれか内で
- ☐ MACHINE_1のApp_B内

Question 66 of 82

Which of the following demonstrates the recommended level of detail for a mobile device encryption policy statement?

- ☐ Data at rest on mobile devices must be secured
- ☐ Mobile devices should be protected with BitLocker full disk encryption
- ☐ Approved third party disk encryption can be used on mobile devices running the Linux operating system
- ☐ The following steps shall be used to enable full disk encryption

全82問中66問目

モバイルデバイスの暗号化ポリシー記述書において推奨される詳細レベルを示すのは、次のうちどれですか？

- ☒ **モバイルデバイスに保存されているデータは保護されなければならない**
- ☐ モバイルデバイスはBitLockerによるフルディスク暗号化で保護されるべきである。
- ☐ 承認されたサードパーティ製のディスク暗号化は、Linuxオペレーティングシステムを実行しているモバイルデバイスで使用できます。
- ☒ **フルディスク暗号化を有効にするには、以下の手順を使用します。**

× あなたは間違っています

ポリシーには、どのように行うべきかではなく、何を行うべきかを記述する高レベルの記述が含まれます。「モバイルデバイスに保存されているデータは保護されなければならない」という記述は、高レベルのポリシー記述の一例であり、標準、ガイドライン、手順といった他のすべての選択肢によって裏付けられています。

Question 67 of 82

A team has verified the version of firmware they will be using in their production HMI's running Windows CE. The authorized version of firmware will be stored in a documented place. What is required to allow future verification of the integrity of the stored, authorized version of the firmware file?

- ☐ Encrypt the file with an asymmetric key
- ☒ **Save the file with restrictive, read-only, privileges**
- ☐ Create a message digest of the official file
- ☐ Load the file onto write-once media

全82問中67問目

あるチームが、Windows CE上で動作する本番環境用HMIで使用するファームウェアのバージョンを確認しました。承認されたファームウェアのバージョンは、文書化された場所に保存されます。保存された承認済みファームウェアファイルの整合性を将来的に検証できるようにするには、何が必要ですか？

- ☐ 非対称鍵でファイルを暗号化する
- ☐ ファイルを読み取り専用の制限付き権限で保存する
- ☒ **公式ファイルのメッセージダイジェストを作成する**
- ☐ ファイルを書き込み専用メディアにロードする

✓ その通りです

組み込み機器の製造に使用するファームウェアのバージョンを決定したら、チームはファイルのハッシュ値（メッセージダイジェスト、ワンウェイハッシュなど）を生成する必要があります。このハッシュ値は、同じハッシュアルゴリズムでファイルを実行し、出力が静的なままであることを確認することで、経時的に比較できます（ファイルが改ざんされていないことを示します）。

Question 68 of 82

In a typical ICS architecture, Purdue Level 3 would include which of the following functions?

- ☐ Patch management servers and site-specific application servers
- ☐ Application firewalls and data guard technology
- ☐ Web facing servers and Simple Mail Transfer Protocol servers
- ☐ Web facing application servers and database servers

全82問中68問目

一般的なICSアーキテクチャにおいて、パーデューレベル3には次のうちの機能が含まれるでしょうか？

- ☒ パッチ管理サーバーおよびサイト固有のアプリケーションサーバー
- ☒ アプリケーションファイアウォールとデータガード技術
- ☐ ウェブサーバーとシンプルメール転送プロトコルサーバー
- ☐ Web向けアプリケーションサーバーとデータベースサーバー

× あなたは間違っています

レベル3 DMZは、インターネットDMZとは異なります。レベル3 DMZには、サービスやデータをゾーン間で共有できる機能固有のゾーンが含まれます。このゾーンに通常含まれるものには、パッチ管理サーバー、ウイルス対策管理システム、サイト固有のアプリケーションサーバー、ジャンプホスト環境、ビジネスインテリジェンスシステム、サイト固有のアプリケーションのバックエンドデータベース、開発システムなどがあります。このゾーンには、Webに面するものは含まれず、また、エンフォースメントゾーンに配置されるアプリケーションファイアウォールやデータガード技術も含まれません。

Question 69 of 82

Which layer of the OSI model does UDP belong to?

- ☐ Layer 5 - Session
- ☐ Layer 3 - Network
- ☐ Layer 4 - Transport
- ☐ Layer 2 - Data Link

全82問中69問目

UDPはOSIモデルのどの層に属しますか？

- ☐ レイヤー5 - セッション
- ☐ レイヤー3 - ネットワーク
- ☒ レイヤー4 - トランスポート
- ☐ レイヤー2 - データリンク

✓ その通りです

TCPと同様に、UDPはトランスポート層で動作します。IPはネットワーク層で動作し、イーサネットなどのプロトコルはデータリンク層で動作します。NetBIOSやRPCなどのプロトコルはセッション層で定義されています。

Question 70 of 82

Which of the following systems logged the Syslog event below?

Jan 23 03:12:414 ip-192-168-10-42 sshd[514]: Invalid user admin from 192.168.10.13

- ☐ The host named sshd
- ☐ The host at 192.168.10.13
- ☐ The host at 192.168.10.42
- ☐ The host named admin

全82問中70問目

以下のシステムのうち、下記のSyslogイベントを記録したのはどれですか？

Jan 23 03:12:414 ip-192-168-10-42 sshd[514]: Invalid user admin from 192.168.10.13

- ☐ sshdという名前のホスト
- ☐ ホストは192.168.10.13です
- ☒ ホストは192.168.10.42です
- ☐ adminという名前のホスト

✔ その通りです

日付/時刻スタンプの後に続くフィールド「ip-192-168-10-42」は、syslogエントリを送信したマシンです。sshdは、エントリを報告したプログラムの名前です。adminとIP 192.168.10.13はどちらもメッセージデータであり、この場合はログインを試みたアカウント名と、その試行が行われたIPアドレスを示しています。

Question 71 of 82

What advantage does the NIST CSF have over the ISO 27001 and ISA/IEC 62443 cybersecurity frameworks?

- ☐ Applies to end-users, system integrators, and security personnel
- ☐ Is available to any organization without cost
- ☐ Enables organizations meeting requirements to be certified
- ☐ Provides guidance on protecting third party information
- ☐ Is applicable to both large and small businesses

NIST CSFは、ISO 27001およびISA/IEC 62443サイバーセキュリティフレームワークと比較して、どのような利点がありますか？

- ☐ エンドユーザー、システムインテグレーター、およびセキュリティ担当者に適用されます。
- ☒ **どの組織でも無料で利用できます**
- ☒ **要件を満たす組織が認証を受けられるようにする**
- ☐ 第三者情報の保護に関するガイダンスを提供する
- ☐ 大企業と中小企業の両方に適用可能

✖ あなたは間違っています

NIST CSFが他のサイバーセキュリティフレームワークよりも優れている点は、無料であることです。ISO 27001とISA/IEC 62443は無料ではありません。これら3つのフレームワークはすべて、組織が改善するためのロードマップを提供します。サイバーセキュリティフレームワークは、規模の大小を問わず、あらゆる組織がエンドユーザー、ハードウェア、ソフトウェア、プロセス、転送中のデータ、サービス、およびアプリケーションを保護するのに役立ちます。ISO 27001の基準に従って監査を正常に完了した組織は、認証を受けることができます。

Question 72 of 82

Which of the following tasks would be done during the containment phase of the incident handling process?

- ☐ An operator scanning an affected system with anti-malware software
- ☐ An incident handler testing a restore process checklist
- ☐ An administrator isolating an affected system on a network
- ☐ A user reporting a system acting abnormally to the help desk

全82問中72問目

インシデント対応プロセスの封じ込めフェーズでは、以下のどのタスクが実施されますか？

- ☐ オペレーターがマルウェア対策ソフトウェアを使用して感染したシステムをスキャンしている
- ☐ インシデントハンドラーが復旧プロセスチェックリストをテストしている
- ☒ **ネットワーク上で影響を受けたシステムを隔離する管理者**
- ☐ ユーザーがシステムの異常動作をヘルプデスクに報告する

✔ その通りです

プロセスチェックリストのテストは準備段階の一部です。異常な動作をしているシステムを報告することは、特定作業です。管理者がネットワーク上で影響を受けたシステムを隔離することは、封じ込め作業です。オペレーターが影響を受けたシステムをスキャンすることは、根絶作業です。

Question 73 of 82

What is a similarity between the Modbus Remote Terminal Unit (RTU) protocol and the Modbus TCP protocol?

- ☐ Neither uses an IP header
- ☐ Neither supports more than one session at a time
- ☐ Both use a transaction ID
- ☐ Both hex encode the request

全82問中73問目

Modbusリモートターミナルユニット（RTU）プロトコルとModbus TCPプロトコルの類似点は何ですか？

- ☒ どちらもIPヘッダーを使用しない
- ☐ どちらも同時に複数のセッションをサポートしていません
- ☐ どちらもトランザクションIDを使用します
- ☒ どちらもリクエストを16進数でエンコードします

✖ あなたは間違っています

Modbus RTUとModbus TCPはどちらもリクエストを16進数でエンコードします。Modbus RTUは一度に1つのセッションしかサポートしませんが、Modbus TCPは複数の通信を同時に行うことができるため、トランザクションIDを追加します。Modbus RTUはネットワーク層を持たないためIPヘッダーを使用しませんが、Modbus TCPはネットワーク層を使用するためIPヘッダーを追加します。

Question 74 of 82

Which of the following Windows event logs would the analyst review in order to determine whether there is a device driver issue?

- ☐ System
- ☐ Application
- ☐ Administrative
- ☐ Security

全82問中74問目

アナリストがデバイスドライバの問題の有無を判断するために確認するWindowsイベントログは次のうちどれですか？

- ☒ システム
- ☐ 応用
- ☐ 管理
- ☒ 安全

✖ あなたは間違っています

デバイスドライバの問題はシステムログに記録されます。管理者が最初に確認すべき場所としては、そこが論理的に適切でしょう。

Question 75 of 82

Which of the following is most effective in ensuring one way data communication from the control system network to a data historian?

- ☐ Routers
- ☐ Data diodes
- ☐ Data concentrator
- ☐ Switch port security

全82問中75問目

制御システムネットワークからデータヒストリアンへの一方向データ通信を確実にするために、次のうちどれが最も効果的ですか？

- ☐ ルーター
- ☒ データダイオード
- ☐ データコンセントレータ
- ☐ スイッチポートのセキュリティ

☒ その通りです

データダイオードは、一方向のデータ通信経路を提供します。データコンセントレータ、ルータ、およびスイッチポートのセキュリティはすべて、それぞれがサポートする通信経路におけるトラフィックの送受信をサポートします。

Question 76 of 82

The file ~/GIAC/hickory.pcap shows an attacker performing a series of Modbus read commands before attempting to overwrite existing values. What is the last packet number containing traffic related to reading holding registers before moving on to actually overwrite values?

[View VM](#)

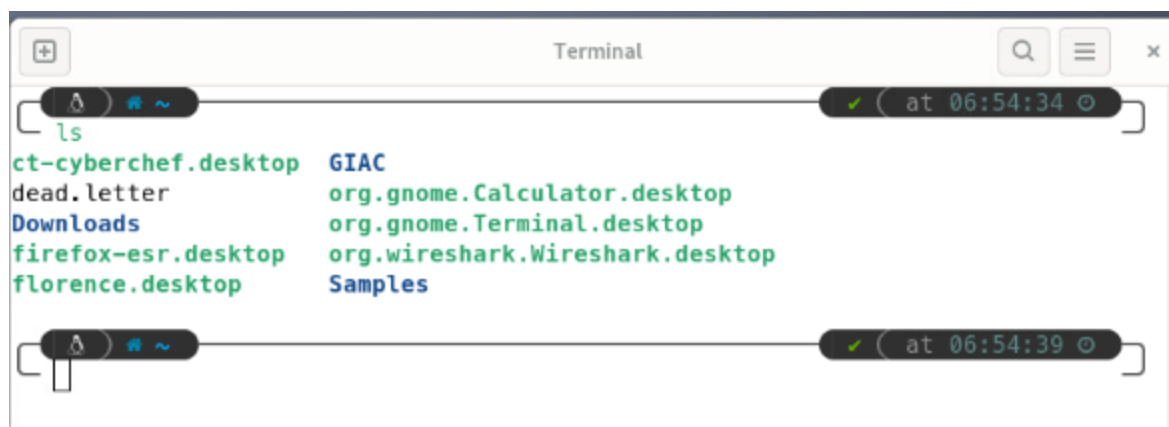
- ☒ 61
- ☐ 9
- ☐ 23
- ☐ 42
- ☐ 7
- ☐ 28
- ☐ 45
- ☐ 8
- ☐ 12

全82問中76問目

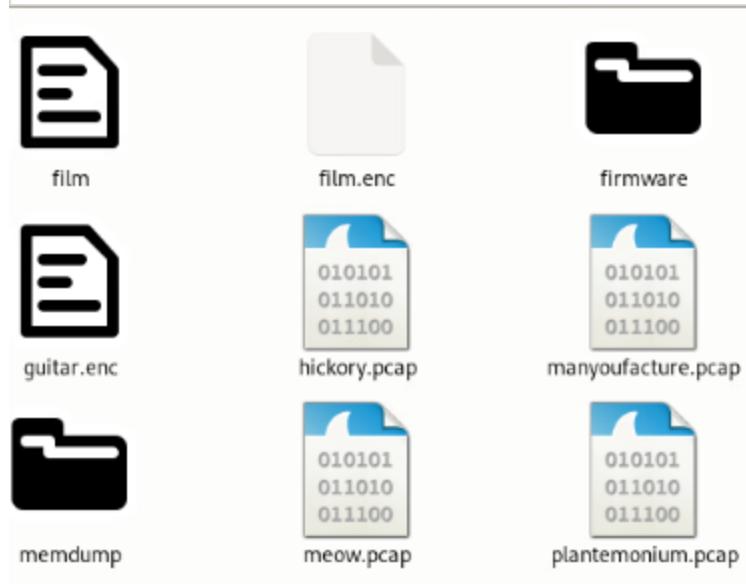
ファイル ~/GIAC/hickory.pcap には、攻撃者が既存の値を上書きしようとする前に、一連の Modbus 読み取りコマンドを実行している様子が示されています。実際に値を上書きする前に、保持レジスタの読み取りに関連するトラフィックを含む最後のパケット番号は何ですか？

VMを表示

- ☐ 61
bdc2fa0bbe4-47ec-a193-8505874050e7 (14266000)
- ☐ 9
- ☐ 23
- ☐ 42
- ☐ 7
- ☐ 28
- ☐ 45
- ☐ 8
- ☐ 12



```
Terminal
ls
ct-cyberchef.desktop  GIAC
dead.letter           org.gnome.Calculator.desktop
Downloads             org.gnome.Terminal.desktop
firefox-esr.desktop  org.wireshark.Wireshark.desktop
florence.desktop      Samples
```



modbus.func_code						
No.	Time	Source	Destination	Length	Leftover Capture Data	Info
14	646.687610	127.0.0.1	127.0.0.1	85		Response: Trans: 13; Unit: 1, Func: 3: Read Holding Registers
16	649.436900	127.0.0.1	127.0.0.1	78		Query: Trans: 14; Unit: 1, Func: 3: Read Holding Registers
17	649.437560	127.0.0.1	127.0.0.1	85		Response: Trans: 14; Unit: 1, Func: 3: Read Holding Registers
19	650.401053	127.0.0.1	127.0.0.1	78		Query: Trans: 15; Unit: 1, Func: 3: Read Holding Registers
20	650.401720	127.0.0.1	127.0.0.1	85		Response: Trans: 15; Unit: 1, Func: 3: Read Holding Registers
22	651.212437	127.0.0.1	127.0.0.1	78		Query: Trans: 16; Unit: 1, Func: 3: Read Holding Registers
23	651.212920	127.0.0.1	127.0.0.1	85		Response: Trans: 16; Unit: 1, Func: 3: Read Holding Registers
25	700.627409	127.0.0.1	127.0.0.1	78		Query: Trans: 17; Unit: 1, Func: 6: Write Single Register
26	700.628681	127.0.0.1	127.0.0.1	78		Response: Trans: 17; Unit: 1, Func: 6: Write Single Register
28	706.032865	127.0.0.1	127.0.0.1	78		Query: Trans: 18; Unit: 1, Func: 6: Write Single Register
29	706.034991	127.0.0.1	127.0.0.1	78		Response: Trans: 18; Unit: 1, Func: 6: Write Single Register
31	711.171327	127.0.0.1	127.0.0.1	78		Query: Trans: 19; Unit: 1, Func: 6: Write Single Register

▶ Frame 23: 85 bytes on wire (680 bits), 85 bytes captured (680 bits)
 ▶ Ethernet II, Src: 00:00:00:00:00:00 (00:00:00:00:00:00), Dst: 00:00:00:00:00:00 (00:00:00:00:00:00)
 ▶ Internet Protocol Version 4, Src: 127.0.0.1, Dst: 127.0.0.1
 ▶ Transmission Control Protocol, Src Port: 10502, Dst Port: 36171, Seq: 309, Ack: 97, Len: 19
 ▶ Modbus/TCP
 ▶ Modbus

Question 76 of 82

The file ~/GIAC/hickory.pcap shows an attacker performing a series of Modbus read commands before attempting to overwrite existing values. What is the last packet number containing traffic related to reading holding registers before moving on to actually overwrite values?

- ☐ 61
- ☐ 9
- ☒ 23
- ☐ 42
- ☐ 7
- ☐ 28
- ☐ 45
- ☐ 8
- ☐ 12

✓ You are correct

Use the display filter modbus.func_code == 3 to find this answer.

Question 77 of 82

What is the userID for the user account **saned** on the host?

[View VM](#)

- ☐ 114
- ☐ 193
- ☐ 149
- ☐ 121
- ☐ 153
- ☐ 177
- ☐ 112
- ☐ 172
- ☐ 111
- ☐ 183

```
id saned
uid=114(saned) gid=121(saned) groups=121(saned),118(scanner)
```

全82問中77問目

sanedホスト上のユーザーアカウントのユーザーIDは何ですか？

- ☒ 114
- ☐ 193
- ☐ 149
- ☐ 121
- ☐ 153
- ☐ 177
- ☐ 112
- ☐ 172
- ☐ 111
- ☐ 183

☒ その通りです

```
cat /etc/passwd | grep saned
```

このファイルの形式は次のとおりです。

```
username : Legacy Password : User ID : Group ID : Notes : Home Directory
: shell
```

Question 78 of 82

Examine the binary file ~/GIAC/memdump/dump with strings. Which function is one of the first 10 functions listed in the binary?

[View VM](#)

- ☐ strchr
- ☐ free
- ☐ alloconsole
- ☐ exitprocess
- ☐ basethreadstart
- ☐ strcmp
- ☐ fflush
- ☐ getprocaddress
- ☐ copyfileExA
- ☐ callback32

```
Terminal
strings /home/control/GIAC/memdump/dump | head
/lib/ld-linux.so.2
__gmon_start__
libc.so.6
_IO_stdin_used
fflush
strcpy
__printf_chk
setlocale
mbrtowc
strncmp
```

全82問中78問目

バイナリファイル ~/GIAC/memdump/dump を文字列とともに調べてください。バイナリファイルにリストされている最初の10個の関数のうちの1つはどれですか？

- ☐ strchr
- ☐ 無料
- ☐ alloconconsole
- ☐ 終了処理
- ☐ ベーススレッド開始
- ☒ strcmp
- ☒ フラッシュ
- ☐ getprocaddress
- ☐ copyfileExA
- ☐ コールバック32

✖ あなたは間違っています

strings コマンド の出力をパイプで渡すと、それが答えとしてless 表示されます。 fflush

Question 79 of 82

Use sqlmap to dump tables from `http://localhost/index.php?page=login.php`. The data necessary for this is as follows:

```
user_name=j
password=p
Submit_button=Submit
```

Which of the following is a table name in the `dojo_control` database?

Hint: The option to dump tables is `--tables`

View VM

- ☐ views
- ☐ applicable_roles
- ☐ files
- ☐ user_variables
- ☐ statistics
- ☐ users
- ☐ engines
- ☐ hitlog
- ☐ events
- ☐ index_statistics

全82問中79問目

sqlmapを使用してからテーブルをダンプします `http://localhost/index.php?page=login.php`。これに必要なデータは次のとおりです。

```
user_name=j
password=p
Submit_button=Submit
```

`dojo_control`データベース内のテーブル名は、次のうちどれですか？

ヒント：テーブルをダンプするオプションは `--tables` です。

VMを表示

- ☐ 閲覧数
- ☐ 適用可能な役割
- ☐ ファイル
- ☐ ユーザー変数
- ☐ 統計
- ☐ ユーザー
- ☐ エンジン
- ☐ ヒットログ
- ☐ イベント
- ☐ インデックス統計

sqlmapを使用してからテーブルをダンプします `http://localhost/index.php?page=login.php`。これに必要なデータは次のとおりです。

```
user_name=j
password=p
Submit_button=Submit
```

dojo_controlデータベース内のテーブル名は、次のうちどれですか？

ヒント：テーブルをダンプするオプションは `--tables` です。

- ☐ 閲覧数
- ☐ 適用可能な役割
- ☐ ファイル
- ☐ ユーザー変数
- ☐ 統計
- ☐ ユーザー
- ☐ エンジン
- ☒ ヒットログ
- ☐ イベント
- ☐ インデックス統計

✔ その通りです

質問に記載されている情報は、sqlmap で以下のように使用できます。

```
sqlmap --fresh-queries -u "http://localhost/index.php?page=login.php" --
data "user_name=j&password=p&submit_button=Submit" --tables
```

What are the last four digits of the hash created when using openssl with the sha3-512 digest on `~/GIAC/film?`

View VM

- ☐ 472b
- ☐ a77f
- ☐ 8c6b
- ☐ 24d7
- ☐ 3b2e
- ☐ 1d50
- ☐ 32e0
- ☐ 8b02
- ☐ e0af
- ☐ 099c

~/GIAC/film に対して openssl を sha3-512 ダイジェストで使った場合に生成されるハッシュの最後の4桁は何ですか？

VMを表示

- ☐ 472b
- ☐ a77f
- ☐ 8c6b
- ☐ 24日7日
- ☐ 3b2e
- ☐ 1d50
- ☐ 32e0
- ☐ 8b02
- ☐ e0af
- ☐ 099c

What are the last four digits of the hash created when using openssl with the sha3-512 digest on ~/GIAC/film?

- ☐ 472b
- ☒ a77f
- ☐ 8c6b
- ☐ 24d7
- ☐ 3b2e
- ☐ 1d50
- ☐ 32e0
- ☒ 8b02
- ☐ e0af
- ☐ 099c

☒ You are incorrect

You can use openssl on the command line or Cyber Chef (launch from terminal) to get this result.

Option: dgst -sha3-512

Question 81 of 82

Examine the control sheet found on the Desktop in the following directory structure:

Velocio PLC\MyChemicalMixer\MyChemicalMixer.vio.

What is the Signal associated with the Flow Input bit tag?

View VM

- ☐ C5
- ☐ C9
- ☐ C8
- ☐ C4
- ☐ C7
- ☐ C3
- ☐ C2
- ☐ C1
- ☐ C6
- ☐ CA

全82問中81問目

デスクトップにある以下のディレクトリ構造内のコントロールシートを確認してくださいVelocio PLC\MyChemicalMixer\MyChemicalMixer.vio。

フロー入力ビットタグに関連付けられている信号は何ですか？

VMを表示

- ☐ C5
- ☐ C9
- ☐ C8
- ☐ C4
- ☐ C7
- ☐ C3
- ☐ C2
- ☐ C1
- ☐ C6
- ☐ カリフォルニア

デスクトップにある以下のディレクトリ構造内のコントロールシートを確認してくださいVelocio PLC\MyChemicalMixer\MyChemicalMixer.vio。

フロー入力ビットタグに関連付けられている信号は何ですか？

- ☐ C5
- ☐ C9
- ☐ C8
- ☐ C4
- ☐ C7
- ☒ C3
- ☐ C2
- ☐ C1
- ☐ C6
- ☐ カリフォルニア

✔ その通りです

Velocioの上部アイコンバーから「タグ」アイコンを選択してください。

表示されたダイアログから「入力ビット」を選択してください。

フロータグに関連付けられたシグナルを特定します。

続く

質問へのフィードバック
を送信

問題が発生しましたか？ここを
クリックして更新してくださ
い。

Examine the control sheet found on the Desktop in the following directory structure:

Velocio PLC\MyChemicalMixer\MyChemicalMixer.vio.

How many Input Bit Tags are being used in this template?

View VM

- ☐ 7
- ☐ 1
- ☐ 8
- ☐ 3
- ☐ 6
- ☐ 4
- ☐ 9
- ☐ 10
- ☐ 5
- ☐ 2

全82問中82問目

デスクトップにある以下のディレクトリ構造内のコントロールシートを確認してください
Velocio PLC\MyChemicalMixer\MyChemicalMixer.vio。

このテンプレートでは、いくつの入力ビットタグが使用されていますか？

- ☐ 7
- ☐ 1
- ☐ 8
- ☐ 3
- ☐ 6
- ☒ 4
- ☐ 9
- ☐ 10
- ☐ 5
- ☐ 2

✔ その通りです

ファイルを開き MyChemicalMixer.vio、上部のバーから「タグ」アイコンを選択してください。

「入力ビット」を選択してください

「使用済み」のチェックボックスがオンになっているタグの数を数えてください。

続く

質問へのフィードバック
を送信

問題が発生しましたか？ここを
クリックして更新してくださ
い。

終了しました

実技試験 合格

得点：73 %（合格）

続く

CyberLive認証バイパス



CyberLiveバイナリファイル解析



サイバーライブ暗号化



CyberLiveエンドポイントのセキュリティ強化、ベースライン、ログ



CyberLiveフィールドバスプロトコル分析



CyberLive産業交通分析



エンドポイントの強化と保護



ICSコンポーネントとアーキテクチャ



ICSの概要と概念



ICSプログラムおよび政策開発



情報収集と脅威モデリング



PERAレベル0および1の技術概要と侵害



PERAレベル2および3の技術概要とリスク



プロトコル、コミュニケーション、そして妥協



リスクベースの災害復旧およびインシデント対応



無線技術とその限界

